

RELATÓRIO INDIVIDUAL PRELIMINAR

DETRAN - Departamento de Trânsito do Estado do Rio de
Janeiro

1. Introdução

Este relatório apresenta os resultados preliminares da organização **DETRAN** relativos à Fiscalização TCE-RJ nº 18/2026, realizada pelo TCE-RJ entre fevereiro e junho de 2026 para avaliar o grau de adoção de práticas de governança e gestão de tecnologia da informação e comunicação pelas organizações jurisdicionadas.

O trabalho abrangeu órgãos e entidades de todos os poderes da Administração Pública Estadual e um conjunto de prefeituras municipais.

2. iGovTI 2026

A avaliação das organizações jurisdicionadas baseia-se no método de autoavaliação de controles (*Control Self-Assessment* – CSA), operacionalizado mediante questionário eletrônico. A ferramenta permitiu aos gestores declarar o nível de adoção das práticas de tecnologia da informação avaliadas e encaminhar a documentação probatória correspondente. As evidências anexadas e as justificativas apresentadas foram submetidas à análise de consistência por esta Equipe de Auditoria, servindo de subsídio para eventuais ajustes na pontuação declarada e para a identificação de inconformidades ou achados de auditoria.

O questionário do iGovTI 2026 foi estruturado com o objetivo de diagnosticar aspectos essenciais de governança e gestão de TIC, abrangendo segurança da informação, gestão de riscos, continuidade de negócios, serviços de tecnologia, contratações de TIC, estrutura e força de trabalho, desenvolvimento de soluções, gestão de projetos e temas emergentes, a exemplo do uso de inteligência artificial. Para além do diagnóstico situacional de cada organização, o instrumento serve como referencial metodológico para futuras ações de melhoria de gestão.

O iGovTI 2026 constitui um índice composto, mensurado em uma escala de 0 a 1. A quantificação do índice inicia-se com a conversão das respostas categóricas declaradas em coeficientes numéricos, conforme os critérios de valoração estabelecidos na Tabela 1.

Tabela 1 - Critérios de valoração das respostas qualitativas do questionário iGovTI 2026

Categoria de Resposta Declarada	Coefficiente Numérico
Não adota	0,00
Há decisão formal ou plano aprovado para adotá-lo	0,05
Adota em menor parte	0,15
Adota parcialmente	0,50

Categoria de Resposta Declarada	Coefficiente Numérico
Adota em maior parte ou totalmente	1,00

(Fonte: elaboração própria)

Nas questões que admitem itens de detalhamento, a pontuação da questão principal sofre deduções proporcionais à quantidade de itens não atendidos pela organização. Subsequentemente, os valores são consolidados por meio de agregação ponderada em uma estrutura hierárquica. O índice final é composto por dois blocos principais, conforme detalhado na Figura 1: **Governança de TIC (peso de 47,8%)**, formado por 4 questões de agregação direta; **Gestão de TIC (iGestTI) (peso de 52,2%)**, estruturado em 6 dimensões operacionais que consolidam 20 questões principais ponderadas.

Figura 1 - Composição do iGovTI 2026



(Fonte: elaboração própria)

Com base na pontuação consolidada do iGovTI 2026, a organização é classificada em um de quatro níveis de maturidade, cujos intervalos de pontuação estão definidos na Tabela 2 e representados graficamente na parte inferior da Figura 1.

Tabela 2 - Intervalos de pontuação para enquadramento nos níveis de maturidade

Nível de Maturidade	Intervalo do Índice (iGovTI)
Inexpressivo	$0,00 \leq \text{iGovTI} < 0,15$
Iniciando	$0,15 \leq \text{iGovTI} < 0,40$

Nível de Maturidade	Intervalo do Índice (iGovTI)
Intermediário	$0,40 \leq \text{iGovTI} < 0,70$
Aprimorado	$0,70 \leq \text{iGovTI} \leq 1,00$

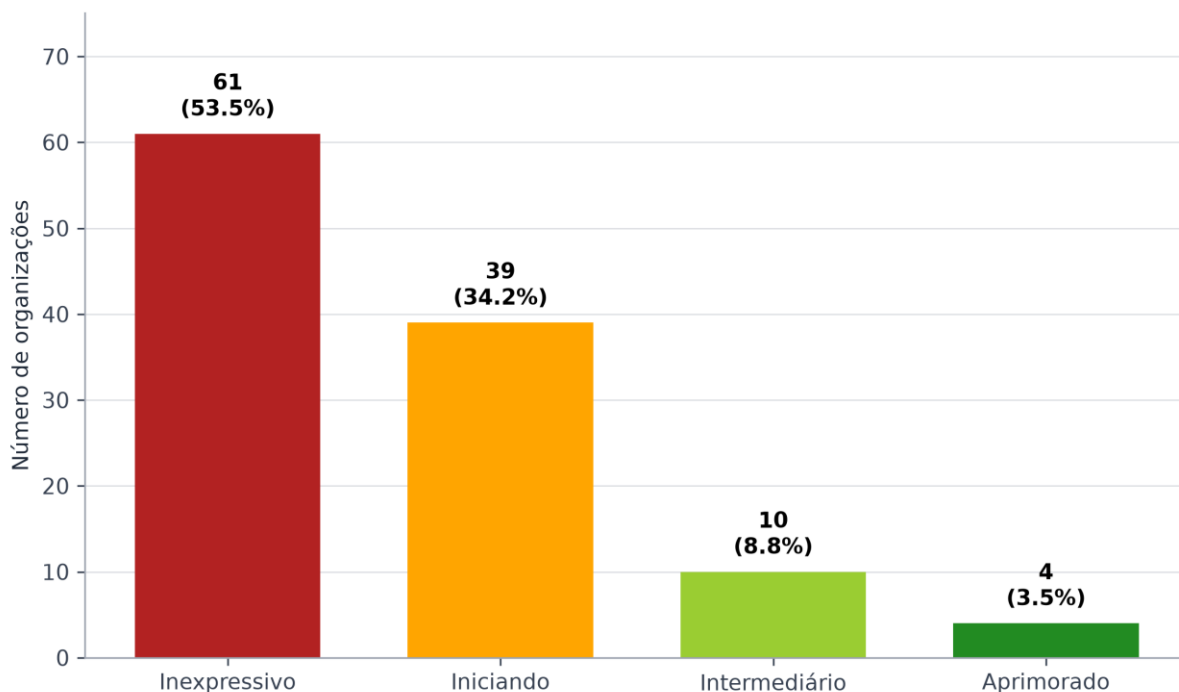
(Fonte: elaboração própria)

2.1. Cenário Geral

A análise consolidada apresentada nesta seção fundamenta-se nos resultados calculados para as 114 organizações que integram o universo amostral da fiscalização. A análise visa contextualizar o resultado individual da organização **DETRAN**, identificar padrões de maturidade, assimetrias entre governança e gestão e capacidades desenvolvidas no conjunto avaliado.

A distribuição por nível de maturidade, apresentada na Figura 2, evidencia concentração nos estágios iniciais. Das 114 organizações, 61 (53,5%) foram classificadas no nível **Inexpressivo** e 39 (34,2%) no nível **Iniciando**. Assim, 100 organizações (87,7%) obtiveram resultado inferior a 0,40. Somente 10 organizações (8,8%) alcançaram o nível **Intermediário** e 4 (3,5%) o nível **Aprimorado**.

Figura 2 - Distribuição das organizações por nível de maturidade do iGovTI 2026



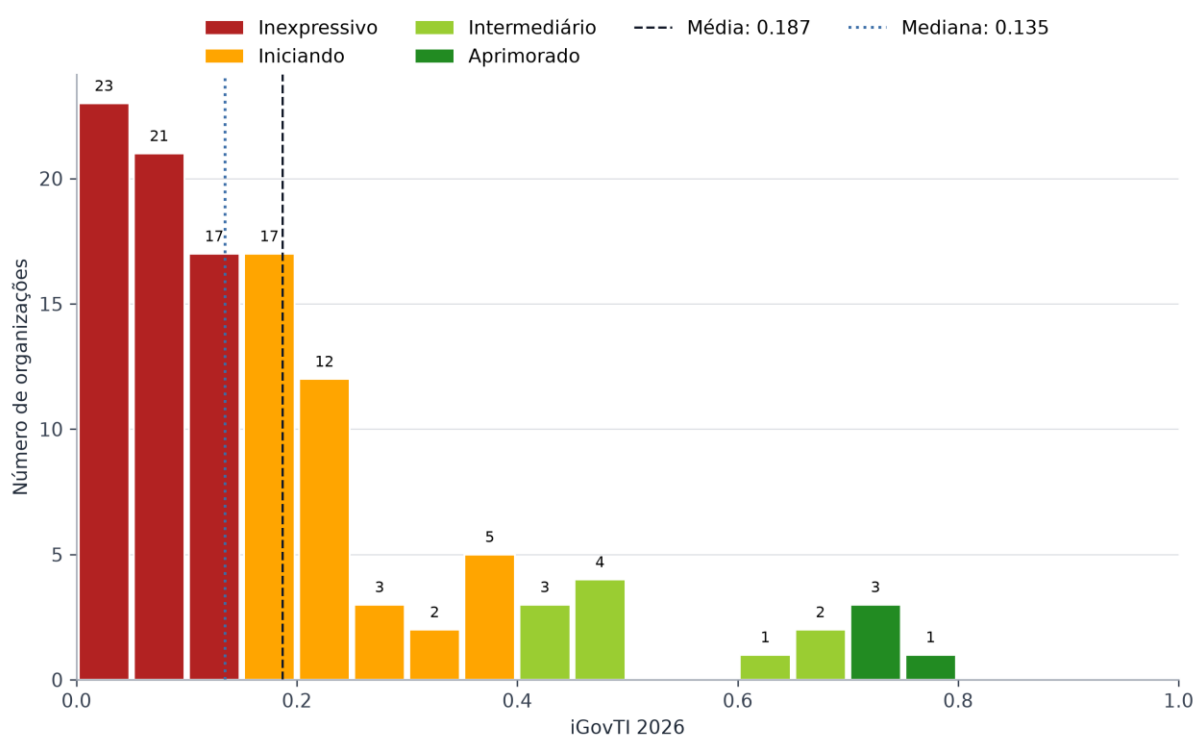
(Fonte: elaboração própria)

O iGovTI apresentou média de 0,187 e mediana de 0,135. O primeiro quartil foi 0,066 e o terceiro quartil, 0,235, o que evidencia a concentração de 50% das organizações avaliadas nesse intervalo, bem como a permanência de pelo menos 75% das entidades

abaixo do nível Intermediário. A divergência positiva entre a média e a mediana, combinada com o valor máximo de 0,777 e com apenas 4 organizações no nível Aprimorado, caracteriza uma distribuição com assimetria à direita (positiva): um grupo reduzido de resultados elevados desloca a média para cima, sem alterar o quadro predominante de baixa maturidade. 5 organizações apresentaram valor igual a zero no índice calculado.

A distribuição contínua da Figura 3 complementa a classificação por faixas e permite observar a concentração dos resultados, os limites de maturidade e a distância entre a mediana e os valores mais elevados.

Figura 3 - Distribuição contínua dos resultados do iGovTI 2026



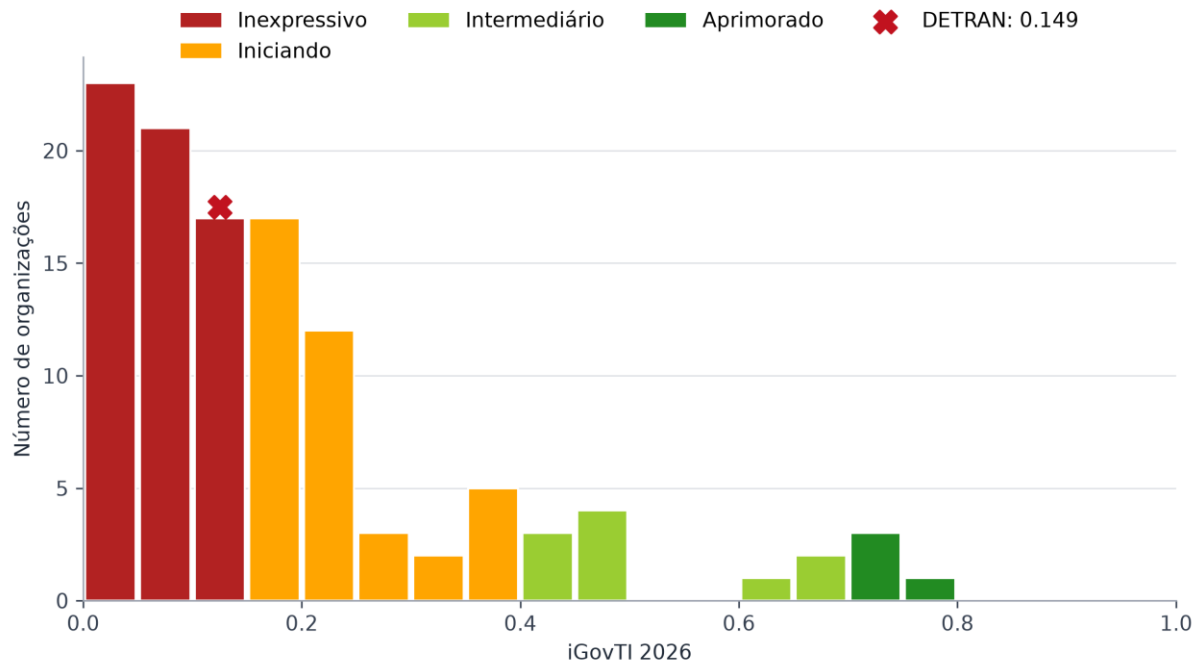
(Fonte: elaboração própria)

A posição específica da organização **DETRAN** nessa distribuição pode ser observada na Figura 4. Diferenças marginais de pontuação entre organizações adjacentes no ranking devem ser interpretadas com cautela analítica, visto que o modelo matemático de composição do índice não pressupõe estimativa de erro amostral e que os resultados estão sujeitos à qualidade e à fidedignidade declaratória do jurisdicionado.

2.2. Cenário atual - DETRAN

Apresentado o panorama geral do universo fiscalizado, esta subseção detalha o desempenho específico da organização jurisdicionada. A organização **DETRAN** obteve o valor **0,1487** para o **iGovTI 2026**, correspondente ao nível **Inexpressivo** de maturidade.

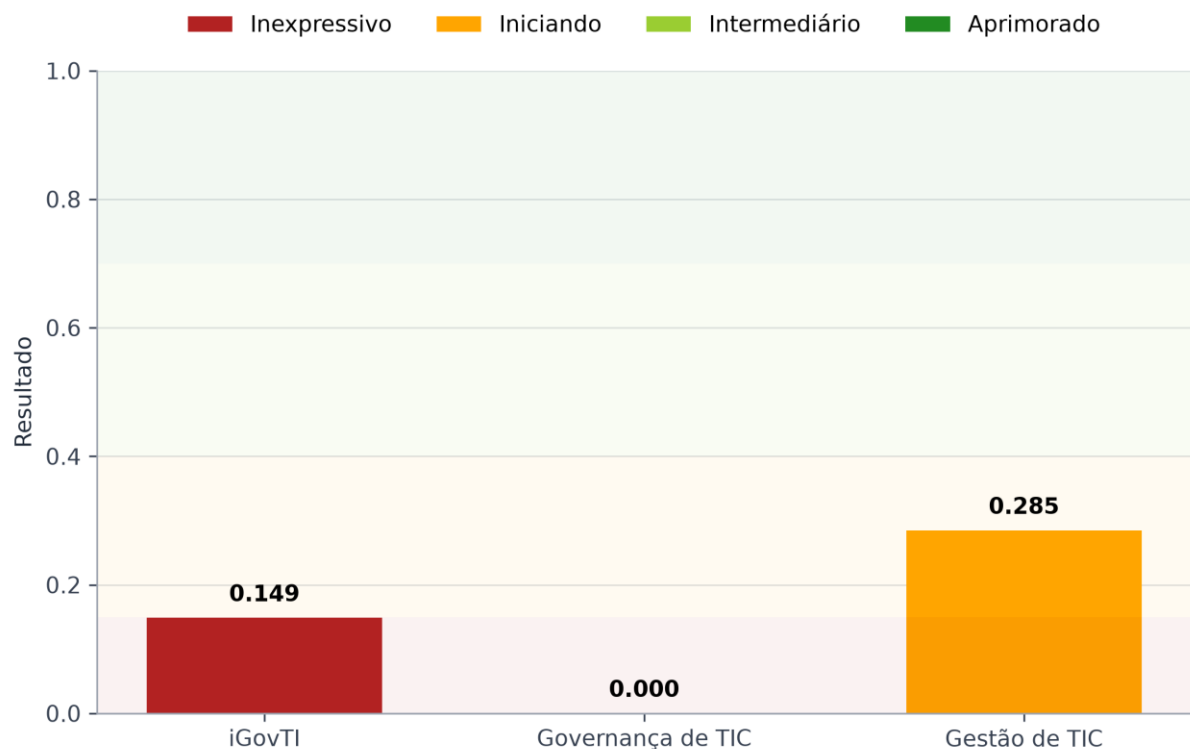
Figura 4 - Distribuição dos resultados do iGovTI 2026 e posição da organização DETRAN



(Fonte: elaboração própria)

A Figura 5 apresenta a composição do resultado da organização **DETRAN** entre governança e gestão de TIC.

Figura 5 - Resultado da organização DETRAN por componentes do iGovTI 2026



(Fonte: elaboração própria)

Tabela 3 - Resultado sintético do iGovTI 2026 da organização DETRAN

Componente	Peso no iGovTI 2026	Valor
Governança de TIC	0,4777	0,0000
Gestão de TIC	0,5223	0,2846
iGovTI 2026	1,0000	0,1487

(Fonte: elaboração própria)

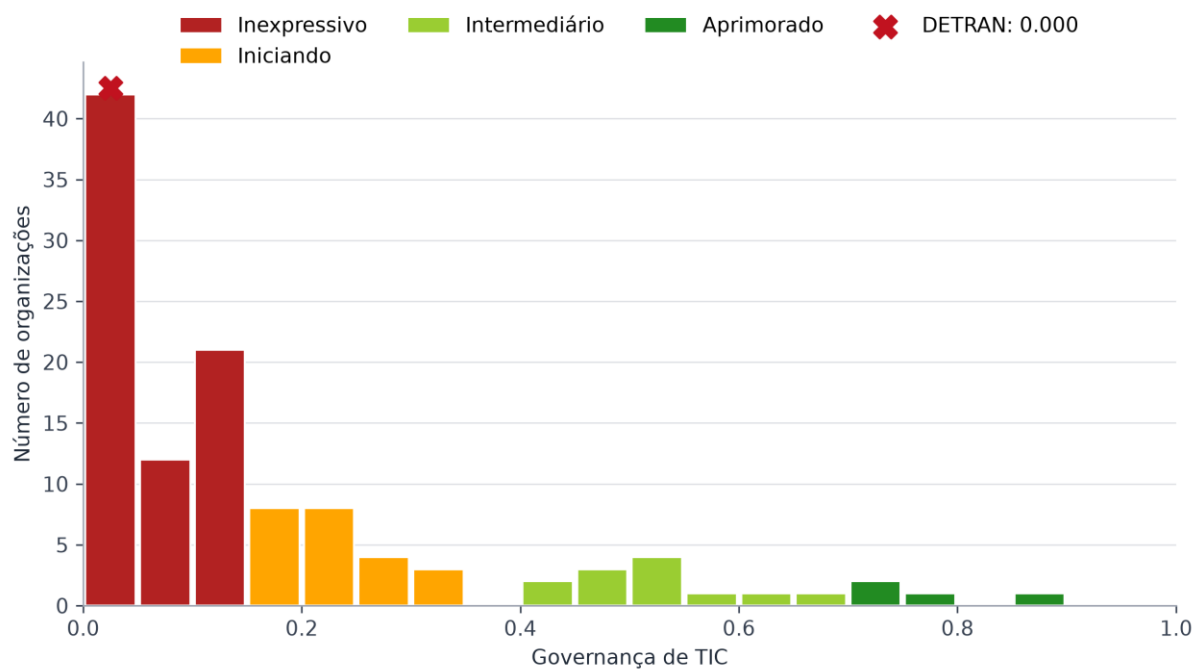
2.2.1. Governança de TIC

A governança de TIC avalia a capacidade da alta administração de orientar, dirigir, monitorar e controlar o uso da tecnologia da informação, de modo alinhado aos objetivos institucionais, aos riscos relevantes e às necessidades das áreas finalísticas e administrativas.

No iGovTI 2026, a dimensão de governança consolida práticas relacionadas ao modelo de gestão de TIC, à atuação de comitês ou instâncias equivalentes, no monitoramento do desempenho, à participação da alta administração e ao alinhamento entre decisões de TIC, estratégia organizacional, orçamento, riscos e valor público.

A organização **DETRAN** obteve o **valor 0,0000 no componente Governança de TIC**.

Figura 6 - Resultado do componente Governança de TIC da organização DETRAN



(Fonte: elaboração própria)

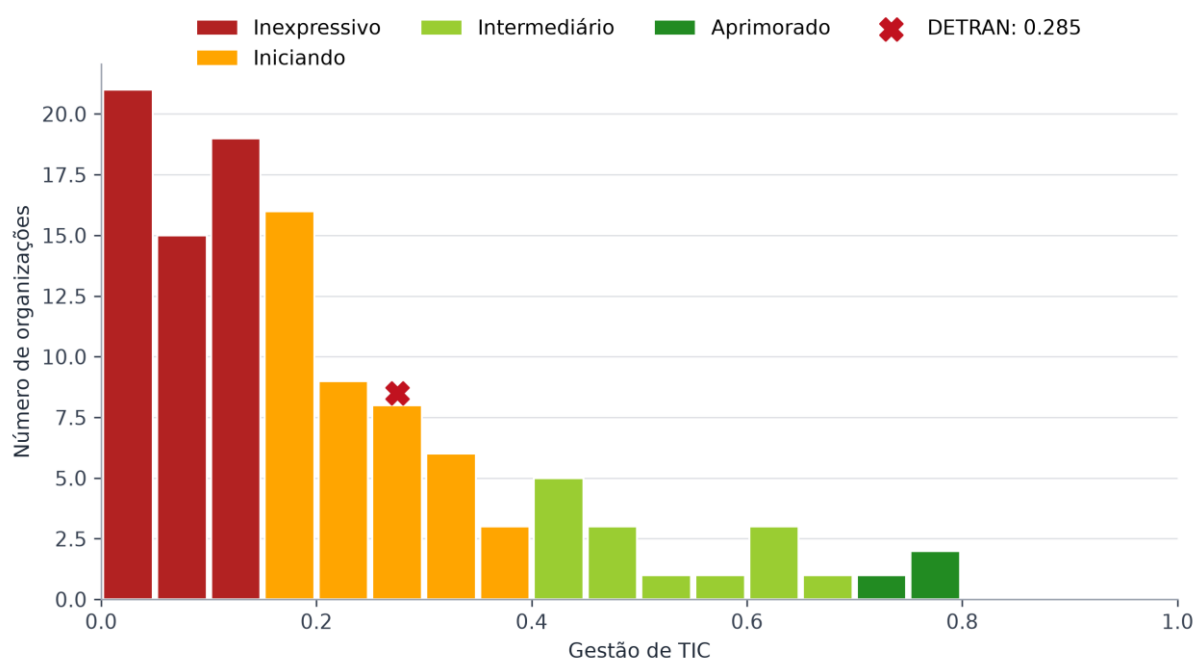
2.2.2. Gestão de TIC

A gestão de TIC avalia a capacidade da organização de planejar, executar, monitorar e aperfeiçoar processos, serviços, controles, recursos e contratações de tecnologia da informação, de forma compatível com suas necessidades institucionais.

No iGovTI 2026, o componente **Gestão de TIC (iGestTI)** consolida seis dimensões operacionais: planejamento de TIC, gestão de serviços de TIC, gestão de riscos de TI e segurança da informação, estrutura de segurança da informação, processos de segurança da informação e gestão de soluções de TIC.

A organização **DETRAN** obteve o valor **0,2846** no componente **Gestão de TIC**.

Figura 7 - Resultado do componente Gestão de TIC da organização DETRAN



(Fonte: elaboração própria)

2.3. Relação entre governança e gestão de TIC

Os indicadores descritivos da Tabela 4 mostram que o componente de gestão apresentou resultados superiores aos de governança no conjunto avaliado. A média da Gestão de TIC foi 0,208, ante 0,164 para Governança de TIC; as medianas foram, respectivamente, 0,153 e 0,117. As duas médias situaram-se no nível Iniciando, enquanto a mediana de Governança de TIC permaneceu no limite superior do nível Inexpressivo e a mediana de Gestão de TIC, no nível Iniciando.

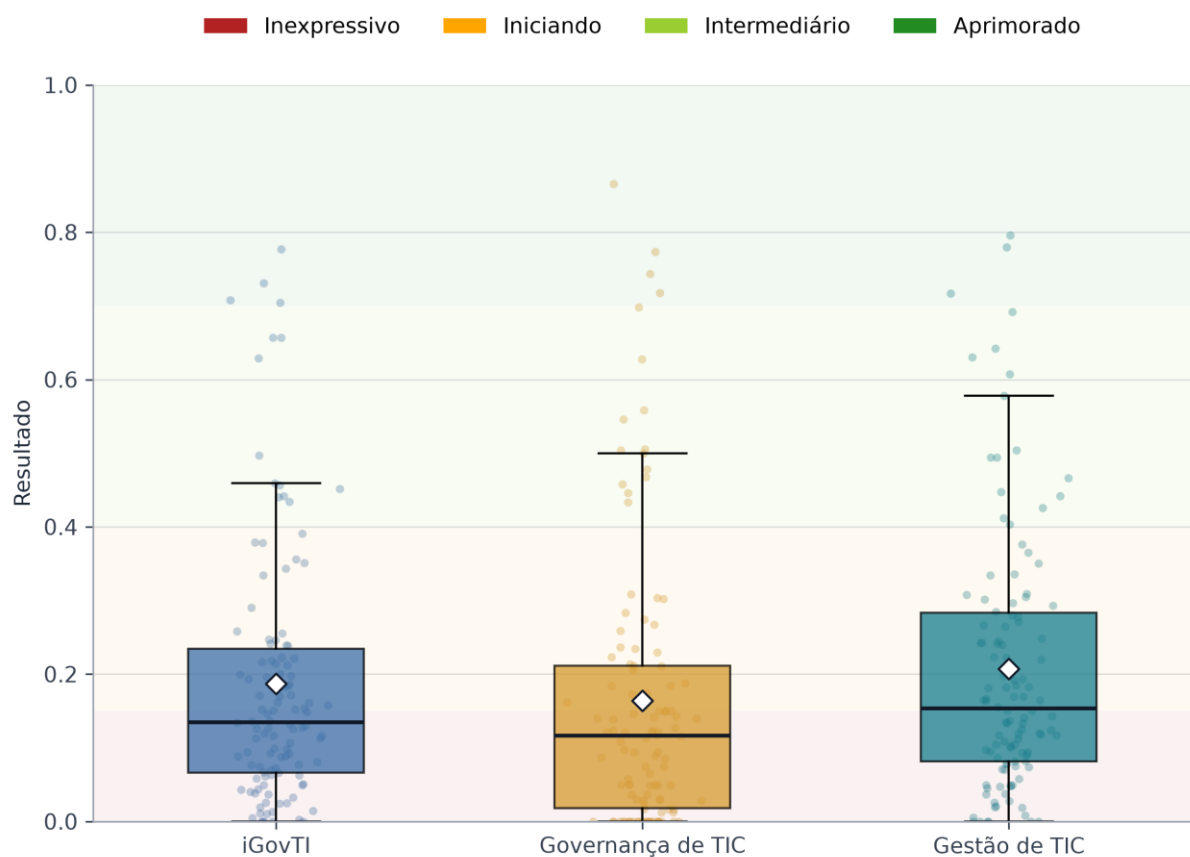
Tabela 4 - Estatísticas descritivas do iGovTI 2026 e de seus componentes principais

Indicador	1º Média	2º quartil	3º Mediana	4º quartil	Organizações com valor >= 0,40	Valor DETRAN
iGovTI	0,187	0,066	0,135	0,235	14 (12,3%)	0,1487
Governança de TIC	0,164	0,018	0,117	0,211	16 (14,0%)	0,0000
Gestão de TIC	0,208	0,082	0,153	0,283	17 (14,9%)	0,2846

(Fonte: elaboração própria)

A Figura 8 permite comparar a dispersão dos três indicadores. O resultado em Gestão de TIC superou o de Governança de TIC em 76 organizações (66,7%); o movimento inverso ocorreu em 33 (28,9%); e houve igualdade em 5 (4,4%). O padrão indica que, para a maior parte das organizações, as capacidades operacionais de gestão se situaram em patamar superior ao dos mecanismos de direção, monitoramento e controle exercidos pela alta administração. Essa diferença, contudo, não elimina a baixa maturidade da gestão: 97 organizações (85,1%) também obtiveram resultado em Gestão de TIC inferior a 0,40.

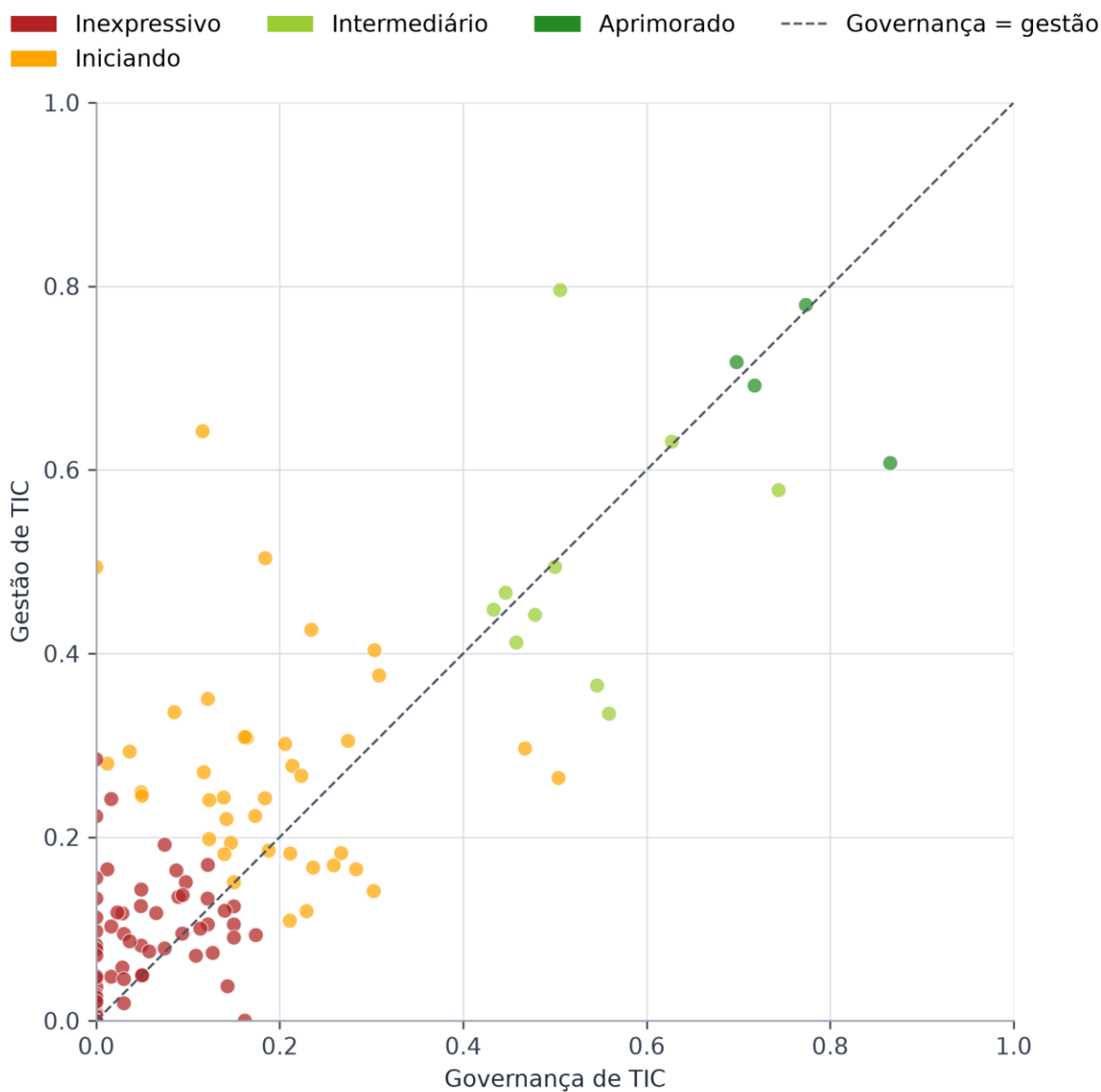
Figura 8 - Distribuição do iGovTI 2026 e dos componentes Governança de TIC e Gestão de TIC



(Fonte: elaboração própria)

A Figura 9 mostra a posição simultânea das organizações nos dois componentes. Pontos abaixo da diagonal representam resultado de gestão superior ao de governança; pontos acima da diagonal representam a situação inversa.

Figura 9 - Relação entre os resultados de governança e gestão de TIC



(Fonte: elaboração própria)

No caso da organização **DETRAN**, o resultado em Governança de TIC ficou abaixo do resultado em Gestão de TIC. Esse perfil indica oportunidade de fortalecer os mecanismos pelos quais a alta administração direciona, monitora e avalia a TIC, especialmente quanto à definição de responsabilidades, objetivos, indicadores, prioridades, riscos e acompanhamento de resultados. A leitura deve ser aprofundada à luz das evidências e dos achados relacionados à governança.

2.4. Dimensões da gestão de TIC

A decomposição da Gestão de TIC revela diferenças relevantes entre as seis dimensões avaliadas. Conforme a Tabela 5, **Planejamento de TIC** apresentou a maior média (0,293) e a maior mediana (0,157). A dimensão com maior média também figurou como a de maior resultado em 50 organizações (43,9%), considerados os empates. Esse padrão indica que algumas capacidades se encontram mais disseminadas do que outras no conjunto fiscalizado.

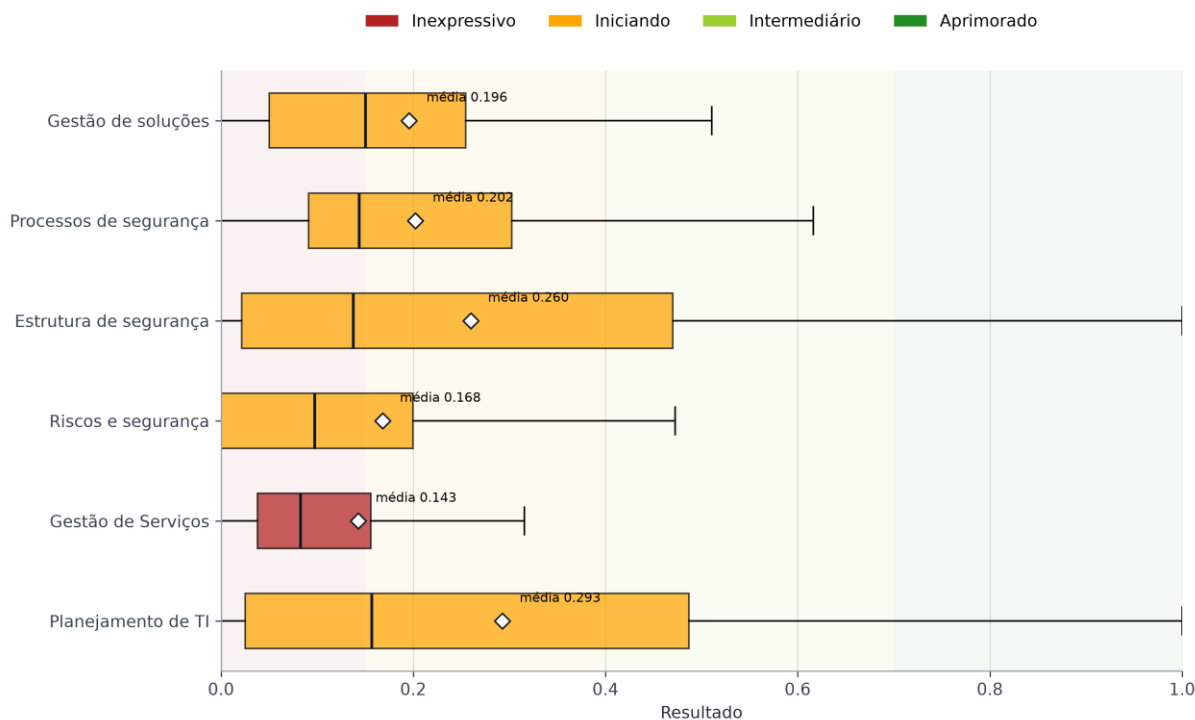
Tabela 5 - Estatísticas descritivas das dimensões de Gestão de TIC

Dimensão	Média	Mediana	Resultados iguais a zero	Organizações com valor inferior a 0,40	Valor DETRAN
Planejamento de TIC	0,293	0,157	21 (18,4%)	80 (70,2%)	0,0747
Gestão de Serviços de TIC	0,143	0,083	20 (17,5%)	102 (89,5%)	0,0000
Gestão de Riscos de TI e Segurança da Informação	0,168	0,097	32 (28,1%)	97 (85,1%)	0,0000
Estrutura de Segurança da Informação	0,260	0,137	25 (21,9%)	83 (72,8%)	0,8115
Processos de Segurança da Informação	0,202	0,144	10 (8,8%)	95 (83,3%)	0,4610
Gestão de Soluções de TIC	0,196	0,150	26 (22,8%)	101 (88,6%)	0,3864

(Fonte: elaboração própria)

A distribuição completa das seis dimensões é apresentada na Figura 10, incluindo medianas, intervalos interquartis e médias.

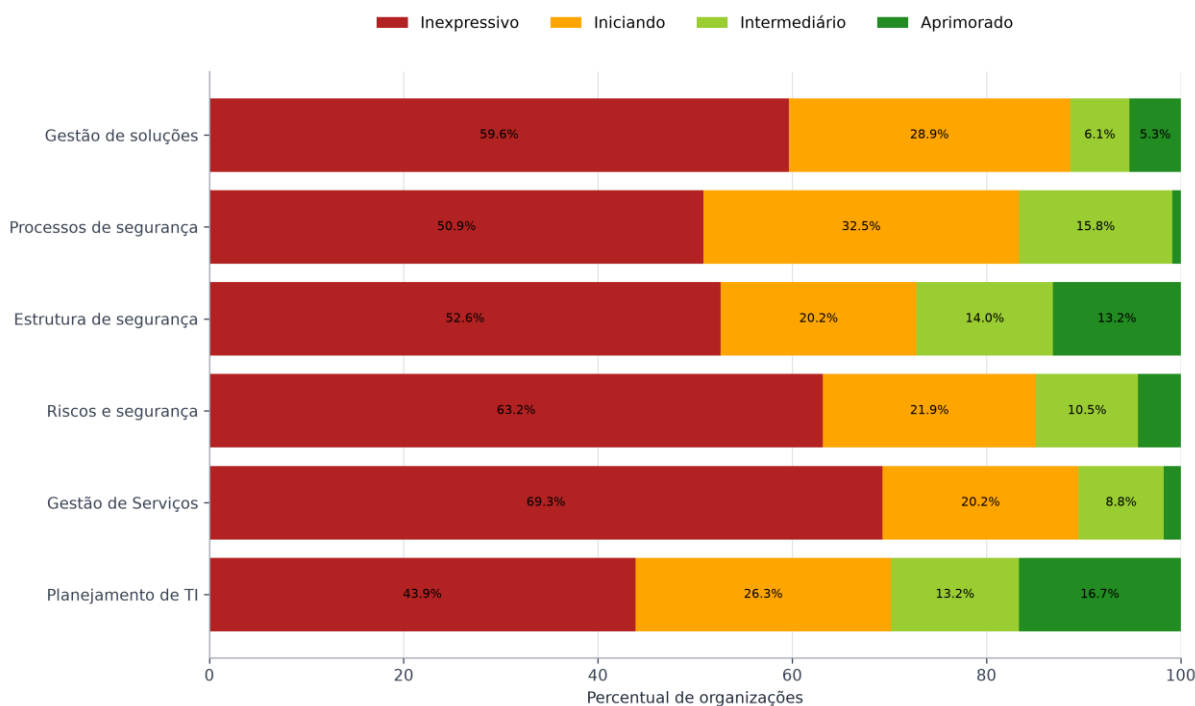
Figura 10 - Distribuição dos resultados das seis dimensões de Gestão de TIC



(Fonte: elaboração própria)

A Figura 11 explicita a composição de cada dimensão por nível de maturidade e permite verificar em quais capacidades se concentram as organizações nos estágios iniciais.

Figura 11 - Distribuição dos níveis de maturidade das organizações nas dimensões de Gestão de TIC



(Fonte: elaboração própria)

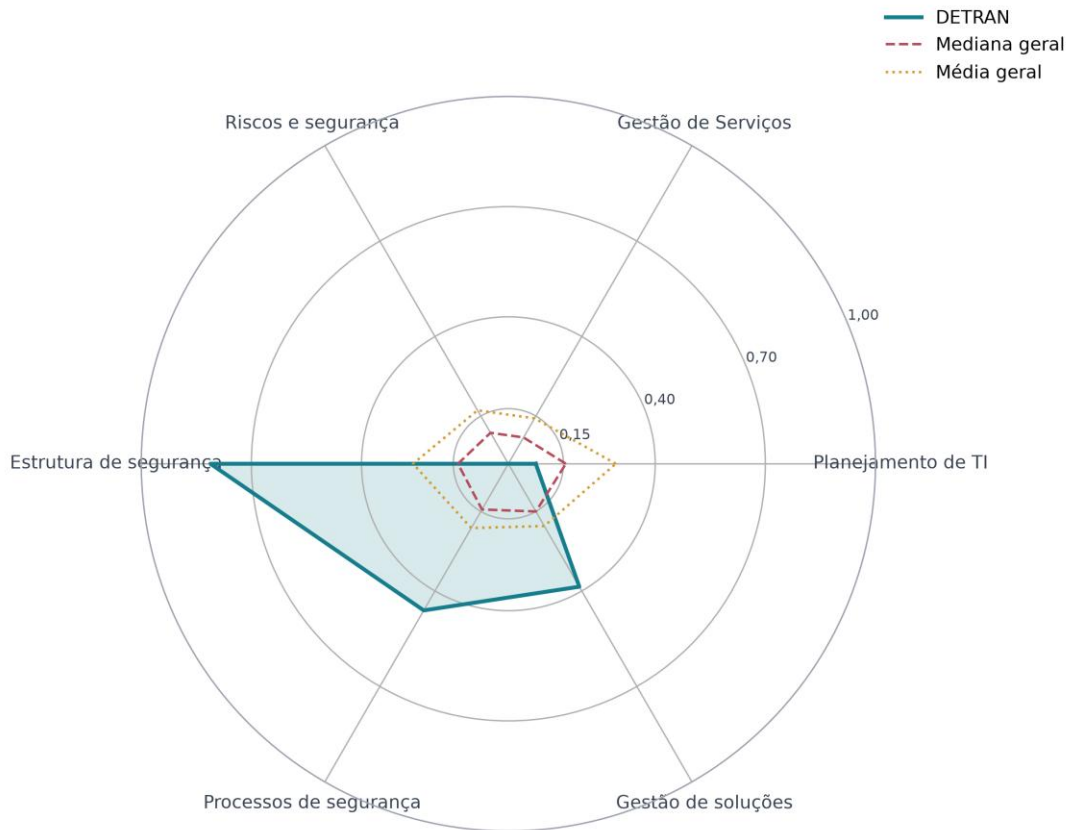
As menores médias foram observadas em **Gestão de serviços de TIC** (0,143) e **Riscos de TI e de segurança da informação** (0,168). A primeira registrou valor inferior a 0,40 em 102 organizações (89,5%) e apareceu entre as dimensões de menor resultado de 37 organizações (32,5%), considerados os empates. Para a segunda, esses quantitativos foram, respectivamente, 97 (85,1%) e 39 (34,2%). O quadro indica que a formalização do planejamento, quando existente, frequentemente não é acompanhada, na mesma intensidade, pelas demais capacidades operacionais e de segurança.

A dimensão Estrutura de Segurança da Informação apresentou média de 0,260 e mediana de 0,137. Essa diferença, associada à ampla dispersão observada na Figura 10, evidencia heterogeneidade: um grupo de organizações possui estruturas de segurança mais consolidadas, enquanto parcela expressiva permanece próxima dos níveis inferiores. A dimensão Processos de Segurança da Informação mostrou mediana superior à de Estrutura de Segurança da Informação, mas 83,3% das organizações ainda permaneceram abaixo de 0,40, o que recomenda examinar separadamente a existência da estrutura formal e a execução contínua dos processos de segurança.

2.5. Leitura integrada do resultado individual

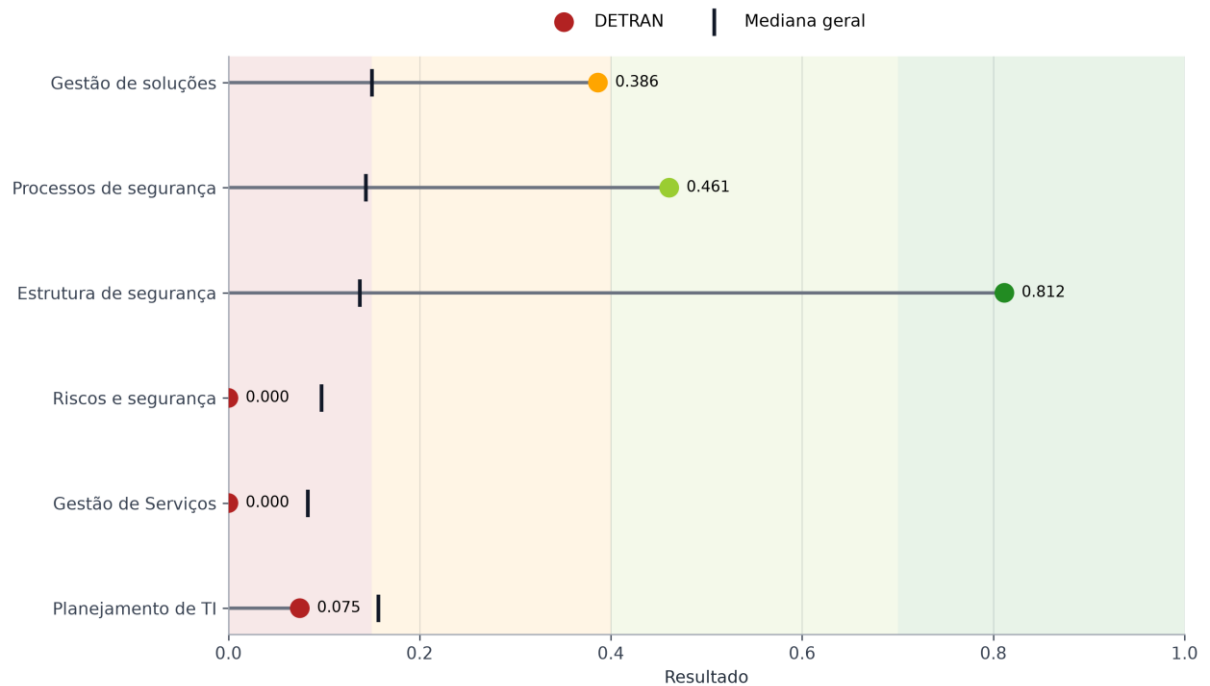
A Figura 12 apresenta o perfil da organização **DETRAN** nas seis dimensões de gestão e o compara com as medianas observadas nas 114 organizações. A comparação linear da Figura 13 permite identificar com maior precisão a distância entre o resultado individual e a mediana geral em cada dimensão.

Figura 12 - Perfil da organização nas dimensões de Gestão de TIC em comparação com os demais



(Fonte: elaboração própria)

Figura 13 - Comparação do resultado individual e da mediana nas dimensões de Gestão de TIC



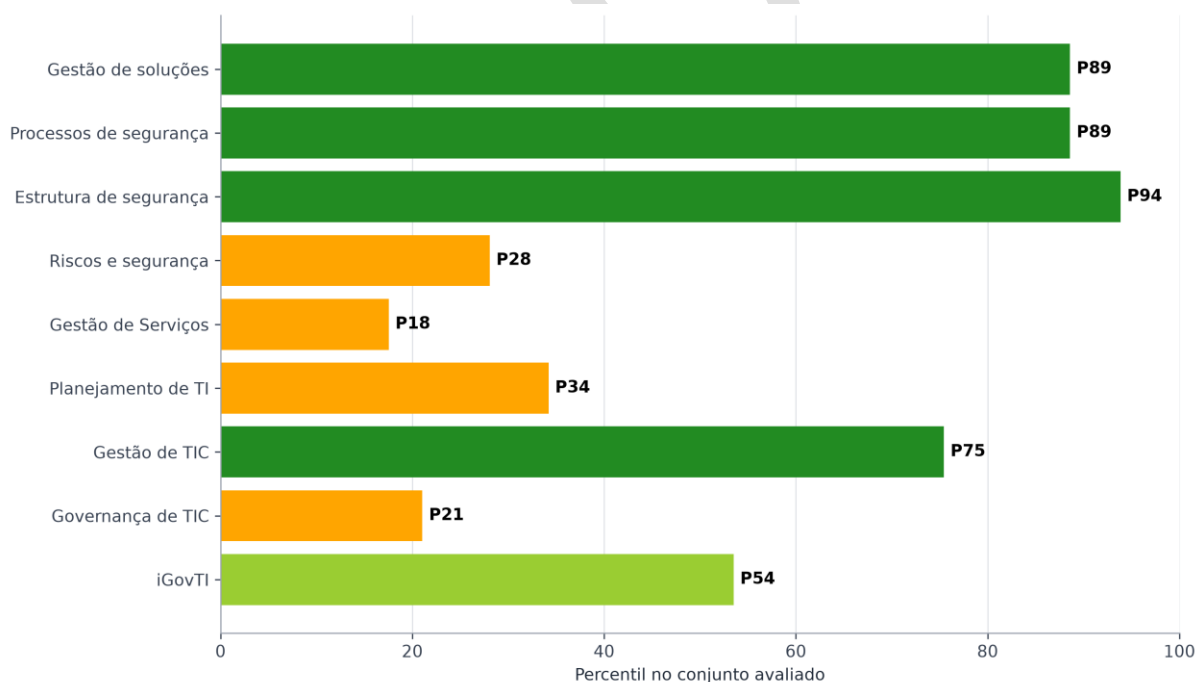
(Fonte: elaboração própria)

O resultado em Planejamento de TIC (0,0747) situa-se nos níveis iniciais de maturidade. Esse resultado indica oportunidade de priorizar a estruturação do planejamento de TIC, de modo a fortalecer a definição de diretrizes, prioridades, responsáveis, recursos, contratações e mecanismos de acompanhamento.

A Figura 14 compara a posição da organização **DETRAN** com as demais organizações avaliadas em cada indicador. A letra “P” indica a posição relativa (percentil) no conjunto: **P50** representa posição próxima ao centro da distribuição; **P90** indica que a organização obteve resultado igual ou superior ao de aproximadamente 90% das organizações avaliadas; e **P20** indica que apenas cerca de 20% das organizações tiveram resultado igual ou inferior. Assim, quanto maior o valor de “P”, melhor é a posição relativa da organização naquele indicador.

Essa comparação deve ser interpretada com cautela. A posição relativa não substitui o valor do índice, o nível de maturidade nem a análise de conformidade realizada nos achados de auditoria. Ela serve apenas para indicar se o resultado da organização ficou relativamente abaixo, próximo ou acima do conjunto avaliado.

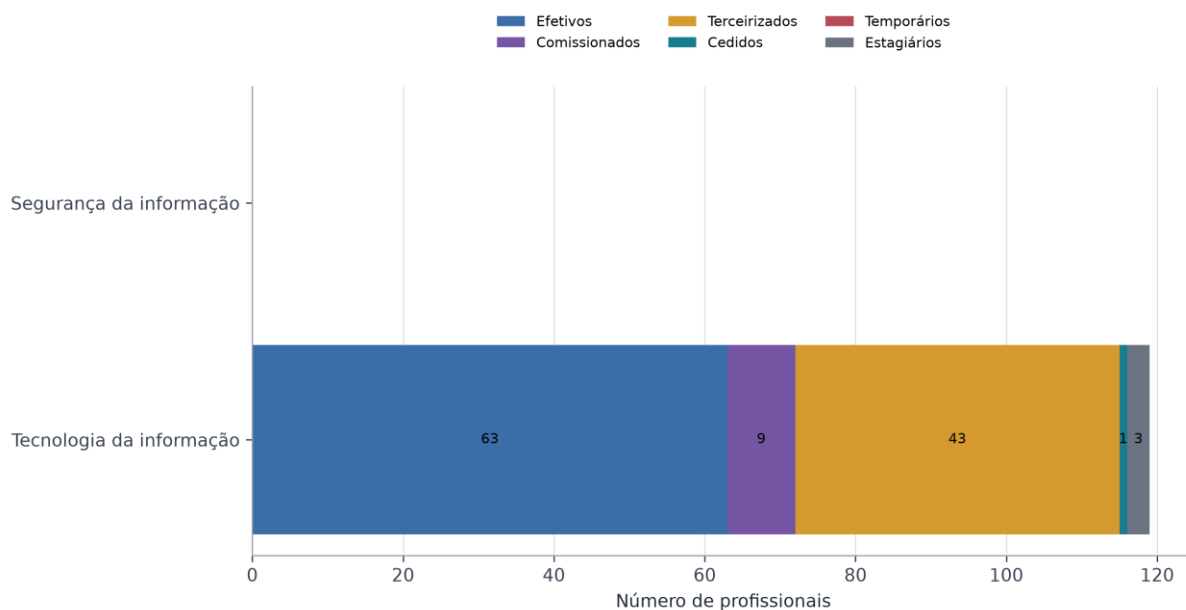
Figura 14 - Comparação da posição relativa da organização DETRAN nos indicadores avaliados



(Fonte: elaboração própria)

A composição declarada da força de trabalho de TIC e de segurança da informação é apresentada na Figura 15. Os quantitativos não compõem o índice e não medem, isoladamente, suficiência de pessoal; sua avaliação depende do porte, da complexidade, da terceirização, dos serviços mantidos e dos riscos da organização.

Figura 15 - Composição declarada da força de trabalho de TIC e segurança da informação



(Fonte: elaboração própria)

2.5.1. Evolução comparável entre 2023 e 2026

A análise longitudinal foi realizada exclusivamente para organizações com correspondência institucional validada nas bases de 2023 e 2026. Para reduzir os efeitos das alterações promovidas no questionário e na estrutura de cálculo, foram utilizados, em ambos os anos, índices ajustados formados por práticas e agregados comparáveis. Esses valores têm finalidade analítica e não substituem os resultados oficiais divulgados em cada ciclo.

No caso da organização **DETRAN**, o iGovTI ajustado comparável passou de 0,3148, em 2023, para 0,0498, em 2026, com variação absoluta de -0,2650.

O resultado indica regressão no conjunto harmonizado de práticas avaliadas, acompanhada da passagem do nível **Iniciando** para o nível **Inexpressivo** de maturidade.

Tabela 6 - Evolução dos componentes ajustados comparáveis da organização DETRAN

Indicador	2023	2026	Variação absoluta
iGovTI ajustado comparável	0,3148	0,0498	-0,2650
Governança de TIC	0,1678	0,0000	-0,1678
Gestão de TIC	0,4618	0,0996	-0,3622

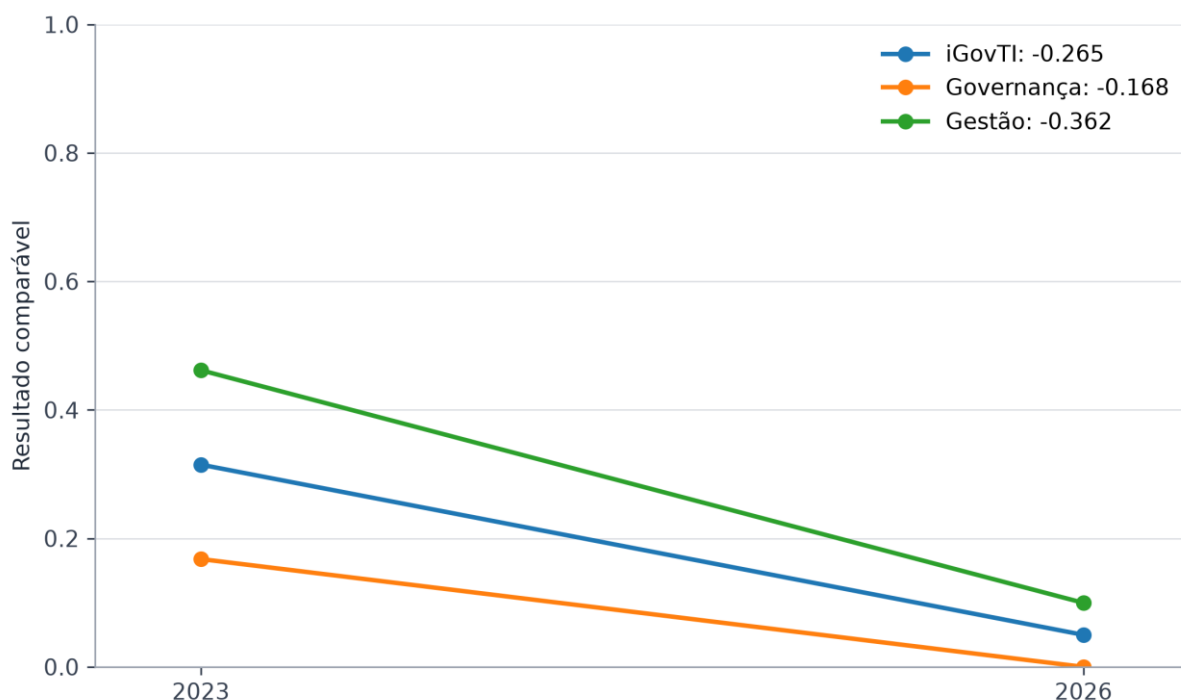
(Fonte: elaboração própria)

Os principais avanços foram observados em Estrutura de segurança da informação (+0.3176); Processos de segurança da informação (+0.1997); Processos de contratação de TIC (+0.0786).

As principais regressões foram observadas em Gestão de pessoas de TIC (-0.4918); Resultados de TIC (-0.4417); Planejamento de TIC (-0.4345).

A Figura 16 apresenta a trajetória dos três indicadores. A variação deve ser interpretada como mudança nas respostas às práticas harmonizadas, e não como comprovação isolada de melhora ou piora da efetividade da TIC. A leitura deve considerar eventuais alterações institucionais, a qualidade das informações declaradas e os achados de auditoria apresentados neste relatório.

Figura 16 - Evolução comparável da organização DETRAN entre 2023 e 2026



(Fonte: elaboração própria)

A priorização de melhorias não deve buscar apenas a elevação numérica do índice. Recomenda-se concentrar esforços nas capacidades com menor resultado que, simultaneamente, estejam associadas a riscos relevantes, serviços críticos, obrigações normativas e necessidades institucionais da organização **DETRAN**.

3. Resultados da Auditoria

No âmbito desta fiscalização, foram definidas questões de auditoria para orientar a avaliação da governança e da gestão de TIC. Para fins deste relatório individual preliminar, os possíveis achados decorrem da verificação das Questões 1 a 6.

Tabela 7 - Questões de auditoria com avaliação individual preliminar

Questão	Tema	Síntese do objeto avaliado
Q1	Estrutura de TIC	Existência formal, atribuições e posicionamento organizacional da área, unidade, setor ou função responsável pela TIC.
Q2	Governança e comitê de TIC	Modelo de governança e gestão de TIC, objetivos, indicadores, metas e atuação do comitê ou instância equivalente.
Q3	Planejamento de TIC	Processo de planejamento, plano de TIC vigente, aprovação, alinhamento institucional, integração orçamentária e acompanhamento.
Q4	Capacidade institucional de TIC e segurança da informação	Força de trabalho, perfis, competências, funções, vínculos e capacidade interna para sustentar a TIC e a segurança da informação.
Q5	Gestão de serviços de TIC	Catálogo de serviços, níveis mínimos de serviço, inventário de ativos, gestão de configuração e tratamento de incidentes.
Q6	Contratações de TIC	Fluxo de contratação, papéis, modelos orientativos, aprovação técnica, alinhamento ao planejamento e equipe de planejamento.

(Fonte: elaboração própria)

Não foram identificados achados individuais preliminares relacionados à Questão 1 para esta organização. Por essa razão, os achados apresentados a seguir preservam a numeração vinculada às questões de auditoria que lhes deram origem.

Os achados de auditoria decorrem da avaliação preliminar das respostas da organização **DETRAN** ao questionário iGovTI 2026 e da correspondente análise de consistência documental realizada por esta Equipe de Auditoria. O trabalho consistiu no confronto sistemático entre as práticas de governança e gestão autodeclaradas pela organização e as evidências comprobatórias efetivamente encaminhadas, à luz da legislação aplicável e de padrões técnicos de referência internacional.

O presente relatório individual adota uma estrutura analítica de apresentação voltada a conferir clareza, rastreabilidade e utilidade diagnóstica às constatações. Desse modo, cada achado de auditoria está estruturado a partir dos seguintes elementos fundamentais:

- **Critérios:** as referências normativas, legais, regulamentares ou de boas práticas de gestão (como os objetivos do COBIT 2019 e normas da série ABNT NBR ISO/IEC) que estabelecem o padrão esperado de conformidade;

- **Evidências:** a relação das informações e dos documentos anexados pela organização que serviram de suporte factual para as constatações;
- **Situação Encontrada:** a descrição detalhada da realidade operacional e documental identificada no jurisdicionado, destacando-se as fragilidades e lacunas específicas em relação aos critérios adotados;
- **Conclusão da Equipe de Auditoria:** a análise técnica e o juízo profissional formulado a partir da correlação entre a situação factual e as regras de controle estabelecidas no mapa de verificação;
- **Propostas de Encaminhamento:** as recomendações preliminares propostas com o intuito de orientar a organização na correção de fragilidades e no aprimoramento de suas capacidades de governança e gestão de TIC.

Cumprе ressaltar o caráter preliminar das constatações ora apresentadas. A disponibilização deste relatório visa subsidiar a fase de comentários do gestor, permitindo à organização apresentar esclarecimentos adicionais, correções de fato ou novas informações que possam orientar a manifestação final desta Corte de Contas.

Achado 2 – Governança de TIC insuficiente para avaliar, dirigir e monitorar a tecnologia da informação.

Critérios

- COBIT 2019, EDM01.02 - Dirigir o sistema de governança: orientar estruturas, princípios, processos e práticas de governança para assegurar que a TI apoie os objetivos organizacionais;
- COBIT 2019, MEA01.04 - Avaliar o desempenho: monitorar e avaliar periodicamente o desempenho e a conformidade da TI em relação a objetivos, indicadores, metas e expectativas das partes interessadas;
- Decreto nº 12.198/2024, art. 5º - Instituição do CGD, colegiado responsável por definir diretrizes e estratégias sobre uso de recursos digitais nos órgãos e entidades da administração pública federal direta, autárquica e fundacional;
- Acórdão TCE-RJ 44.490/2024-PLEN, item II.1: necessidade de estrutura de governança de TI, especialmente Comitê de Tecnologia da Informação ou instância equivalente, com participação de áreas relevantes, responsabilidade de alinhar as ações de TI aos objetivos institucionais, priorizar investimentos e monitorar o desempenho da TI com base em indicadores e metas;
- COBIT 2019, APO01.05 - Estabelecer papéis e responsabilidades: definir, comunicar e manter papéis e responsabilidades relacionados à governança e gestão de TI.

Evidências

- **E1:** A organização declarou “Sim” no subitem c) do item 1001, mas a evidência encaminhada foi considerada insuficiente para comprovar que define os papéis e responsabilidades da área de gestão de tecnologia da informação;
 - Justificativa da avaliação: O documento define papéis e responsabilidades restritos à segurança da informação e privacidade, como os previstos nos artigos 13 a 16 da POSIC. Não há evidência que descreva a estrutura de responsabilidades da área de tecnologia da informação em sua totalidade;
- **E2:** A organização declarou “Sim” no subitem h) do item 1001, mas a evidência encaminhada foi considerada insuficiente para comprovar que estabeleceu objetivos, indicadores e metas para a gestão de tecnologia da informação;
 - Justificativa da avaliação: Não constam no documento apresentado objetivos, indicadores ou metas para a gestão de TI. A POSIC trata apenas de diretrizes de segurança, sendo insuficiente para atender a este quesito;

- **E3:** A organização declarou “Sim” no subitem a) do item 1002, mas a evidência encaminhada foi considerada insuficiente para comprovar que rotinas de monitoramento do desempenho da gestão de tecnologia da informação estão definidas;
 - Justificativa da avaliação: A POSIC estabelece diretrizes para a segurança da informação, mas não define rotinas, periodicidade ou processos voltados ao monitoramento do desempenho da gestão de tecnologia da informação. A documentação fornecida é insuficiente para atender ao requisito de existência de rotinas de medição de performance da área de TI;
- **E4:** A organização declarou “Sim” no subitem c) do item 1002, mas a evidência encaminhada foi considerada insuficiente para comprovar que os indicadores de desempenho da gestão de tecnologia da informação estão implantados (há coleta e análise dos dados necessários à medição de desempenho);
 - Justificativa da avaliação: Não foram apresentadas evidências da implantação de indicadores de desempenho (KPIs) voltados à gestão de TI. Não constam documentos que demonstrem a existência de processos para a coleta e análise de dados de performance da área;
- **E5:** A organização declarou “Sim” no subitem e) do item 1001, mas a evidência encaminhada foi considerada insuficiente para comprovar que dispõe de comitê de tecnologia da informação composto por representantes de áreas relevantes da organização;
 - Justificativa da avaliação: A documentação apresentada não faz qualquer menção à existência ou composição de um comitê de tecnologia da informação. Não foi possível verificar a conformidade deste ponto;
- **E6:** A organização declarou “Sim” no subitem f) do item 1001, mas a evidência encaminhada foi considerada insuficiente para comprovar que o comitê de tecnologia da informação realiza as atividades previstas em ato constitutivo;
 - Justificativa da avaliação: Dada a inexistência de comprovação documental sobre a constituição ou existência de um comitê de tecnologia da informação, não é possível validar o exercício de suas atividades.

Situação encontrada

A governança de TIC compreende o conjunto de estruturas, papéis, responsabilidades, diretrizes e mecanismos de acompanhamento por meio dos quais a alta administração avalia, dirige e monitora o uso da tecnologia da informação. Sua finalidade é

assegurar que os recursos de TIC apoiem os objetivos institucionais, sejam priorizados de forma transparente e tenham desempenho acompanhado com base em critérios objetivos.

Para que a governança de TIC esteja estruturada, a alta administração deve estabelecer modelo básico de governança e gestão de TIC, com papéis, responsabilidades, objetivos, indicadores e metas claras, além de assegurar a existência e o funcionamento regular de um Comitê de TIC ou instância colegiada equivalente.

Os critérios de boas práticas orientam que a organização deve dirigir o sistema de governança, monitorar o desempenho e a conformidade da TIC, definir papéis e responsabilidades e instituir instância colegiada capaz de alinhar ações de TIC aos objetivos institucionais, priorizar investimentos e acompanhar o desempenho com base em indicadores e metas¹. Esses requisitos convergem com a necessidade de instância colegiada de governança digital, conforme diretriz do Decreto nº 12.198/2024², e com as deliberações do Acórdão TCE-RJ 44.490/2024-PLEN³.

Com base na análise das respostas aos itens 1001 e 1002 do questionário aplicado e da avaliação das evidências documentais anexadas, não foi demonstrado atendimento integral a esses requisitos de governança. A Equipe de Auditoria identificou fragilidades nos seguintes aspectos:

- **Modelo básico de governança e gestão de TIC:** a ausência ou insuficiência de modelo formalizado não demonstra aderência aos critérios de direção do sistema de governança e avaliação de desempenho (COBIT 2019, EDM01.02/MEA01.04) e ao Acórdão TCE-RJ 44.490/2024-PLEN (item II.1), gerando baixa clareza sobre papéis, responsabilidades, objetivos, indicadores e metas da TIC.
- **Instituição do Comitê de TIC:** a não instituição formal não se alinha ao Acórdão TCE-RJ 44.490/2024-PLEN (item II.1), ao COBIT 2019 (APO01.05) e à diretriz de referência do Decreto nº 12.198/2024 (art. 5º), dificultando a existência de instância colegiada para deliberação sobre prioridades, projetos, riscos, serviços, orçamento e contratações de TIC.
- **Atuação do Comitê de TIC:** a ausência de atuação efetiva contraria os critérios de avaliação de desempenho de estruturas colegiadas (COBIT 2019, MEA01.04 e Acórdão TCE-RJ 44.490/2024-PLEN, item II.1) e a diretriz de referência do Decreto

¹ No COBIT 2019, o sistema de governança deve ser dirigido por estruturas, princípios, processos e práticas que assegurem que a TI apoie os objetivos organizacionais, com papéis e responsabilidades definidos e desempenho periodicamente monitorado.

² O Decreto nº 12.198/2024 disciplina, no âmbito federal, o Comitê de Governança Digital como colegiado responsável por diretrizes e estratégias sobre o uso de recursos digitais, servindo como referência normativa para a estruturação de instâncias colegiadas de governança digital.

³ O Acórdão TCE-RJ 44.490/2024-PLEN, item II.1, registra a necessidade de estrutura de governança de TI, especialmente Comitê de Tecnologia da Informação ou instância equivalente, com participação de áreas relevantes e atribuições de alinhamento, priorização e monitoramento.

nº 12.198/2024 (art. 5º), o que pode comprometer a deliberação regular sobre prioridades, projetos, riscos, serviços, orçamento e contratações de TIC.

Essas situações ensejaram o presente achado e serão detalhadas nas subseções seguintes.

Modelo básico de governança e gestão de TIC

O modelo básico de governança e gestão de TIC deve explicitar como a alta administração orienta, acompanha e responsabiliza a atuação da tecnologia da informação. Esse modelo deve conter, ao menos, diretrizes, papéis, responsabilidades, objetivos, indicadores, metas e forma de acompanhamento periódico.

O COBIT 2019, no objetivo EDM01.02, orienta a direção do sistema de governança por meio de estruturas, princípios, processos e práticas que assegurem que a TI apoie os objetivos organizacionais. Em complemento, o objetivo MEA01.04 trata do monitoramento e da avaliação periódica do desempenho e da conformidade da TI em relação a objetivos, indicadores, metas e expectativas das partes interessadas.

A existência e a suficiência desse modelo devem ser demonstradas por políticas, diretrizes, definição de papéis e responsabilidades, objetivos, indicadores, metas, relatórios de acompanhamento, medições de desempenho ou instrumentos equivalentes.

Da análise das respostas aos itens 1001 e 1002 e da documentação apresentada, verificou-se que o modelo básico de governança e gestão de TIC não se mostrou suficientemente estruturado quanto a papéis, responsabilidades, objetivos, indicadores, metas ou forma de acompanhamento periódico, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem c) do item 1001, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que define os papéis e responsabilidades da área de gestão de tecnologia da informação (E1);
- No subitem h) do item 1001, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que estabeleceu objetivos, indicadores e metas para a gestão de tecnologia da informação (E2);
- No subitem a) do item 1002, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que rotinas de monitoramento do desempenho da gestão de tecnologia da informação estão definidas (E3);
- No subitem c) do item 1002, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que os indicadores de desempenho da gestão de tecnologia da informação estão implantados (há coleta e análise dos dados necessários à medição de desempenho) (E4).

A ausência ou a insuficiência de um modelo básico de governança e gestão de TIC acarreta o risco de indefinição sobre a direção estratégica da tecnologia da informação e sobre os resultados esperados da função de TIC.

Instituição formal do Comitê de TIC ou instância equivalente

O Comitê de TIC ou instância equivalente é mecanismo relevante para estruturar a participação da alta administração e das áreas interessadas nas decisões de tecnologia da informação. Sua formalização permite definir composição, competências, periodicidade mínima, forma de deliberação e responsabilidades pelo acompanhamento das decisões.

O Decreto nº 12.198/2024, art. 5º, adotado como critério de referência, prevê colegiado responsável por definir diretrizes e estratégias sobre uso de recursos digitais no âmbito federal. O Acórdão TCE-RJ 44.490/2024-PLEN, item II.1, reforça a necessidade de estrutura de governança de TI, especialmente Comitê de Tecnologia da Informação ou instância equivalente, com participação de áreas relevantes.

Em alinhamento, o COBIT 2019, no objetivo APO01.05, orienta a definição, comunicação e manutenção de papéis e responsabilidades relacionados à governança e gestão de TI.

A instituição formal do Comitê deve ser demonstrada por ato, norma, regimento, portaria ou documento equivalente que estabeleça a instância, sua composição, competências, periodicidade ou forma de deliberação.

Da análise das respostas ao item 1001 e da documentação apresentada, verificou-se que a instituição formal de Comitê de TIC ou instância equivalente não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem e) do item 1001, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que dispõe de comitê de tecnologia da informação composto por representantes de áreas relevantes da organização (E5).

A ausência de instituição formal do Comitê de TIC ou instância equivalente fragiliza a governança, uma vez que a organização deixa de contar com foro institucional normatizado para deliberação sobre prioridades, projetos, riscos, serviços, orçamento e contratações de TIC.

Atuação efetiva do Comitê de TIC ou instância equivalente

A instituição formal isolada do Comitê de TIC ou instância equivalente não é suficiente para assegurar governança efetiva. É necessário que a instância funcione de modo regular, com reuniões, pautas, atas, registros de deliberação, encaminhamentos e acompanhamento das decisões tomadas.

O COBIT 2019, no objetivo MEA01.04, exige monitoramento e avaliação periódica do desempenho e da conformidade da TI. O Acórdão TCE-RJ 44.490/2024-PLEN, item II.1, também aponta a responsabilidade de alinhar as ações de TI aos objetivos institucionais, priorizar investimentos e monitorar o desempenho da TI com base em indicadores e metas.

A atuação efetiva do Comitê deve ser demonstrada por atas, pautas, listas de presença, registros de deliberação, decisões, encaminhamentos ou acompanhamento de pendências. A ausência desses registros dificulta verificar se a instância colegiada exerce, de fato, seu papel de avaliação, direção e monitoramento da TIC.

Da análise das respostas ao item 1001 e da documentação apresentada, verificou-se que a atuação efetiva do Comitê de TIC ou instância equivalente não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem e) do item 1001, a organização declarou dispor de comitê de tecnologia da informação composto por representantes de áreas relevantes, mas a evidência foi insuficiente para comprovar a prática declarada (E5);
- No subitem f) do item 1001, a organização declarou atuação do comitê de tecnologia da informação, mas a evidência foi insuficiente para comprovar a prática declarada (E6).

Essa fragilidade operacional reduz a segurança de que decisões relevantes sobre prioridades, projetos, riscos, serviços, orçamento e contratações de TIC sejam submetidas ao crivo colegiado ou monitoradas formalmente.

Conclusão

As fragilidades identificadas na governança de TIC reduzem a segurança de que a organização disponha de mecanismos suficientes para avaliar, dirigir e monitorar a tecnologia da informação de forma alinhada aos objetivos institucionais.

Em razão das lacunas descritas, são propostas recomendações preliminares voltadas à estruturação e à adequação dos mecanismos de governança de TIC efetivamente apontados neste achado, observados os critérios aplicáveis indicados nas seções anteriores.

Propostas de Encaminhamento

- **Comunicação com Recomendação** para que estabeleça modelo básico de governança e gestão de TIC, atentando-se, minimamente, em definir papéis e responsabilidades, objetivos, indicadores, metas e forma de acompanhamento periódico do desempenho da TIC pela alta administração;

- **Comunicação com Recomendação** para que institua formalmente Comitê de TIC ou instância equivalente, compatível com o porte e a estrutura decisória da organização, atentando-se, minimamente, em definir sua composição, competências, periodicidade de reuniões, forma de registro das deliberações e acompanhamento dos encaminhamentos;
- **Comunicação com Recomendação** para que assegure o funcionamento efetivo do Comitê de TIC ou instância equivalente, compatível com o porte e a estrutura decisória da organização, atentando-se, minimamente, em realizar reuniões periódicas, registrar deliberações e acompanhar decisões sobre prioridades, projetos, riscos, serviços, orçamento e contratações de TIC.

Achado 3 – Planejamento de TIC insuficiente para orientar a gestão, o orçamento e as contratações de TIC

Critérios

- COBIT 2019, APO02.05 - Definir o plano e o roteiro estratégico: estabelecer plano e roteiro de TIC que traduzam a estratégia em iniciativas, prioridades, recursos, dependências, prazos e benefícios esperados;
- COBIT 2019, APO06.03 - Criar e manter orçamentos: elaborar e manter orçamento de TIC alinhado ao portfólio, ao planejamento e às prioridades aprovadas;
- Acórdão 1.411/2014-TCU-Plenário, item 9.1.6 e subitens 9.1.6.1 a 9.1.6.4: necessidade de instituir formalmente plano diretor de TI, contemplando desdobramento de diretrizes estratégicas, vinculação das ações de TI a indicadores e metas de negócio, vinculação das ações de TI a indicadores e metas de serviços ao cidadão e vinculação das ações priorizadas ao orçamento de TI;
- Acórdão TCE-RJ 44.490/2024-PLEN, item II.3 e subitens II.3.1 a II.3.5: necessidade de estabelecer processo estruturado, com participação de representantes das principais secretarias, para elaborar, manter e revisar periodicamente o PDTI, contemplando objetivos, indicadores e metas de TI alinhados aos objetivos de negócio, riscos que possam impactar objetivos e metas, projetos, aquisições e ações necessárias, alocação de recursos e ações de divulgação e monitoramento do PDTI após aprovação pela autoridade máxima.

Evidências

- **E1:** A organização declarou “Sim” no subitem a) do item 2101, mas a evidência encaminhada foi considerada insuficiente para comprovar que as áreas demandantes de soluções de TI participam do processo de planejamento de tecnologia da informação;
 - Justificativa da avaliação: A avaliação realizada indica que não há comprovação da participação de áreas demandantes no planejamento de TI. Não foram apresentados registros, atas ou normativos que evidenciassem tal envolvimento nas ações de tecnologia da informação. A evidência é insuficiente, dada a ausência total de documentação que relacione demandas de áreas internas com o planejamento de tecnologia;
- **E2:** A organização declarou “Sim” no subitem b) do item 2101, mas a evidência encaminhada foi considerada insuficiente para comprovar que estabeleceu critérios

para orientar a seleção e a priorização das iniciativas de TI (projetos e ações) e os mantêm atualizados;

- Justificativa da avaliação: A avaliação realizada indica que a organização não estabeleceu critérios formais de seleção e priorização de iniciativas de TI. O pacote probatório não contém matrizes, rankings, catálogos de priorização ou instrumentos análogos que orientem decisões de TI. A evidência é insuficiente por omitir a formalização de critérios técnicos ou gerenciais para a priorização de investimentos em tecnologia;
- **E3:** A organização declarou “Sim” no subitem c) do item 2101, mas a evidência encaminhada foi considerada insuficiente para comprovar que as análises de benefícios, de custos e de riscos subsidiam as decisões relacionadas à seleção e à priorização das iniciativas de TI (projetos e ações);
 - Justificativa da avaliação: A avaliação realizada indica a inexistência de análises de benefícios, custos ou riscos para subsidiar decisões de TI. Não constam estudos de viabilidade, business cases ou análises multicritério referentes a projetos de tecnologia da informação. A evidência é insuficiente devido à ausência de documentos técnicos que fundamentem a seleção ou priorização de iniciativas de TI;
- **E4:** A organização declarou “Sim” no subitem d) do item 2101, mas a evidência encaminhada foi considerada insuficiente para comprovar que o processo de planejamento de TI está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades);
 - Justificativa da avaliação: A avaliação realizada indica que o processo de planejamento de TI não está formalizado. Não foi apresentado normativo interno, guia ou portaria que discipline a execução do planejamento, a definição de responsabilidades e as orientações para o processo de TI no âmbito da organização. A evidência é insuficiente pela total ausência de instrumento formal que regule a governança e o planejamento de TI;
- **E5:** Resposta negativa ao detalhamento a) do item 2102 do Questionário, para verificar se o plano de tecnologia da informação (plano de TI) é aprovado pelo dirigente máximo da organização ou por dirigente ou colegiado que integra a alta administração;
- **E6:** Resposta negativa ao detalhamento d) do item 2102 do Questionário, para verificar se as iniciativas de TI (projetos e ações) constantes do plano de TI alinham-se aos objetivos e iniciativas definidos no planejamento institucional (como PPA,

planos estratégicos, planos setoriais e plano de governo, no caso de municípios), bem como, quando aplicável, às estratégias e diretrizes estabelecidas por instâncias superiores de governança (como a Estratégia Nacional de Tecnologia da Informação e Comunicação do Poder Judiciário - ENTIC-JUD, normas e orientações do SETIC/PRODERJ (para órgãos estaduais) ou instâncias de governança equivalentes no âmbito municipal);

- **E7:** Resposta negativa ao detalhamento c) do item 2102 do Questionário, para verificar se o plano de TI fundamenta a proposta orçamentária da área de TI e o plano de contratações;
- **E8:** Resposta negativa ao detalhamento c) do item 2802 do Questionário, para verificar se na elaboração do PCA são considerados os demais instrumentos de planejamento da organização;
- **E9:** A organização declarou “Sim” no subitem d) do item 2802, mas a evidência encaminhada foi considerada insuficiente para comprovar que o PCA fundamenta a proposta orçamentária da organização;
 - Justificativa da avaliação: A Portaria estabelece o fluxo de verificação de disponibilidade orçamentária por meio da Assessoria de Planejamento e Orçamento (ASSPLAN) em processos de contratação individuais. Não existe evidência documental ou normativa que demonstre que o Plano de Contratações Anual (PCA) sirva como base de fundamentação para a elaboração da proposta orçamentária global da organização;
- **E10:** Resposta negativa ao subitem b) do item 2804 do Questionário, para verificar se as contratações de TI executadas no exercício encontram-se previamente estabelecidas nos instrumentos de planejamento vigentes (PDTI/PEDTIC e PCA);
- **E11:** Resposta negativa ao detalhamento e) do item 2102 do Questionário, para verificar se é feito acompanhamento concomitante à execução do plano de TI, com vistas a assegurar sua observância e possibilitar a realização de ajustes que se fizerem necessário.

Situação encontrada

O planejamento de TIC é instrumento fundamental para traduzir diretrizes institucionais em iniciativas, prioridades, recursos, prazos, responsáveis e resultados esperados. Sob a perspectiva de governança pública, a administração deve executar processo formal de planejamento, contar com plano de TIC formalmente aprovado, assegurar participação das áreas finalísticas, alinhar o plano ao planejamento institucional, integrá-lo ao orçamento e às contratações e acompanhá-lo periodicamente.

Os critérios de boas práticas indicam que o planejamento de TIC deve estabelecer plano e roteiro estratégico, manter orçamento alinhado ao portfólio e às prioridades aprovadas, vincular ações de TIC a indicadores, metas e orçamento de TI, e contemplar processo estruturado de elaboração, manutenção e revisão periódica do PDTI⁴.

Com base na análise das respostas aos itens 2101, 2102, 2802 e 2804 do questionário aplicado e da avaliação das evidências documentais anexadas, não foi demonstrado atendimento integral a esses requisitos de planejamento. A Equipe de Auditoria identificou fragilidades nos seguintes aspectos:

- **Processo formal de planejamento:** a fragilidade no processo de elaboração não demonstra aderência aos critérios do COBIT 2019 (APO02.05), do Acórdão 1.411/2014-TCU-Plenário e do Acórdão TCE-RJ 44.490/2024-PLEN, o que pode favorecer atuação reativa e sem critérios objetivos de seleção e priorização de iniciativas.
- **Aprovação formal do plano:** a ausência de aprovação formal não demonstra aderência aos critérios de formalização do planejamento de TIC, reduzindo sua legitimidade institucional para orientar a gestão, os projetos, o orçamento e as contratações da organização.
- **Alinhamento estratégico:** a falta de alinhamento ao planejamento institucional não demonstra aderência ao princípio de vinculação da TIC aos objetivos de negócio, o que pode resultar em investimentos e iniciativas com baixo valor público para o órgão.
- **Integração orçamentária e operacional:** a ausência de vínculo demonstrado com orçamento e contratações de TIC não demonstra aderência ao COBIT 2019 (APO06.03), ao Acórdão 1.411/2014-TCU-Plenário e ao Acórdão TCE-RJ 44.490/2024-PLEN, favorecendo aquisições reativas, não priorizadas e desalinhadas das metas de TIC.
- **Acompanhamento e revisão:** a ausência de acompanhamento ou atualização periódica não demonstra aderência aos critérios de manutenção e monitoramento do PDTI, elevando o risco de manutenção de metas, iniciativas e prioridades incompatíveis com mudanças institucionais, orçamentárias ou tecnológicas.

Essas situações ensejaram o presente achado e serão detalhadas nas subseções seguintes.

⁴ Os critérios de planejamento de TIC convergem para a necessidade de plano formal, aprovado, vigente, alinhado à estratégia institucional, integrado ao orçamento e às contratações e acompanhado periodicamente.

Processo formal de planejamento de TIC

O processo formal de planejamento de TIC deve definir etapas, responsáveis, participação das áreas demandantes e critérios mínimos de priorização. Esse processo é necessário para que o planejamento deixe de ser uma atividade eventual e passe a constituir rotina institucional de identificação, seleção, priorização e acompanhamento de demandas de tecnologia.

O COBIT 2019, no objetivo APO02.05, orienta a definição de plano e roteiro estratégico de TIC que traduzam a estratégia em iniciativas, prioridades, recursos, dependências, prazos e benefícios esperados. O Acórdão TCE-RJ 44.490/2024-PLEN, item II.3, também aponta a necessidade de processo estruturado, com participação de representantes das principais secretarias, para elaborar, manter e revisar periodicamente o PDTI.

O processo deve ser demonstrado por norma, procedimento, guia ou instrumento equivalente que discipline a elaboração, revisão, aprovação e acompanhamento do planejamento de TIC.

Da análise das respostas ao item 2101 e da documentação apresentada, verificou-se que o processo formal de planejamento de TIC não se mostrou suficientemente estruturado quanto a etapas, responsáveis, participação das áreas demandantes e critérios de priorização, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2101, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que as áreas demandantes de soluções de TI participam do processo de planejamento de tecnologia da informação (E1);
- No subitem b) do item 2101, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que estabeleceu critérios para orientar a seleção e a priorização das iniciativas de TI (projetos e ações) e os mantém atualizados (E2);
- No subitem c) do item 2101, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que as análises de benefícios, de custos e de riscos subsidiam as decisões relacionadas à seleção e à priorização das iniciativas de TI (projetos e ações) (E3);
- No subitem d) do item 2101, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o processo de planejamento de TI está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades) (E4).

A inexistência ou fragilidade desse processo expõe a organização a uma atuação reativa e à alocação de recursos em iniciativas de tecnologia sem critérios claros de priorização.

Aprovação formal do plano de TIC

O plano de TIC deve ser formalmente aprovado pelo dirigente máximo da organização ou por dirigente ou colegiado integrante da alta administração, de modo a conferir legitimidade institucional ao instrumento.

O Acórdão 1.411/2014-TCU-Plenário e o Acórdão TCE-RJ 44.490/2024-PLEN reforçam a necessidade de plano diretor ou instrumento equivalente formalmente instituído e aprovado, capaz de orientar as ações de TIC.

A aprovação deve ser demonstrada por ato formal da instância competente ou por registro equivalente que identifique o plano aprovado, a autoridade responsável e a data da deliberação.

Da análise das respostas ao item 2102 e da documentação apresentada, verificou-se que a aprovação formal do plano de TIC por autoridade ou instância competente não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2102, não houve declaração afirmativa quanto à prática avaliada: o plano de tecnologia da informação (plano de TI) é aprovado pelo dirigente máximo da organização ou por dirigente ou colegiado que integra a alta administração (E5).

A ausência de comprovação da aprovação formal do plano de TIC reduz a segurança quanto à legitimidade institucional do instrumento para orientar a gestão, os projetos, o orçamento e as contratações de tecnologia da informação.

Alinhamento ao planejamento institucional

O plano de TIC deve demonstrar como suas iniciativas apoiam os objetivos institucionais, as diretrizes superiores e as necessidades das áreas finalísticas e administrativas.

O Acórdão 1.411/2014-TCU-Plenário exige o desdobramento de diretrizes estratégicas e a vinculação das ações de TI a indicadores e metas de negócio. O Acórdão TCE-RJ 44.490/2024-PLEN também prevê objetivos, indicadores e metas de TI alinhados aos objetivos de negócio.

Da análise das respostas ao item 2102 e da documentação apresentada, verificou-se que o alinhamento do plano de TIC ao planejamento institucional, às diretrizes superiores ou às necessidades das áreas finalísticas e administrativas não se mostrou suficientemente demonstrado, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem d) do item 2102, não houve declaração afirmativa quanto à prática avaliada: as iniciativas de TI (projetos e ações) constantes do plano de TI alinham-se aos objetivos e iniciativas definidos no planejamento institucional (como PPA, planos estratégicos, planos setoriais e plano de governo, no caso de municípios), bem como, quando aplicável, às estratégias e diretrizes estabelecidas por instâncias superiores de governança (como a Estratégia Nacional de Tecnologia da Informação e Comunicação do Poder Judiciário - ENTIC-JUD, normas e orientações do SETIC/PRODERJ (para órgãos estaduais) ou instâncias de governança equivalentes no âmbito municipal) (E6).

A ausência desse alinhamento eleva o risco de execução de iniciativas tecnológicas pouco aderentes às prioridades institucionais, às necessidades das áreas finalísticas e administrativas e à geração de valor público.

Vínculo com orçamento e contratações de TIC

O planejamento de TIC deve ser vinculado com a proposta orçamentária, o plano de contratações e as contratações executadas. Essa integração é necessária para que as iniciativas priorizadas tenham suporte financeiro, sejam convertidas em contratações coerentes e possam ser acompanhadas ao longo da execução.

O COBIT 2019, APO06.03, orienta a criação e manutenção de orçamento de TIC alinhado ao portfólio, ao planejamento e às prioridades aprovadas. O Acórdão 1.411/2014-TCU-Plenário também exige vinculação das ações priorizadas ao orçamento de TI, e o Acórdão TCE-RJ 44.490/2024-PLEN prevê projetos, aquisições, ações necessárias e alocação de recursos no PDTI.

Da análise das respostas aos itens 2102, 2802 e 2804 e da documentação apresentada, verificou-se que o vínculo entre o plano de TIC, a proposta orçamentária, o plano de contratações ou as contratações de TIC executadas não se mostrou suficientemente demonstrado, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem c) do item 2102, não houve declaração afirmativa quanto à prática avaliada: o plano de TI fundamenta a proposta orçamentária da área de TI e o plano de contratações (E7);
- No subitem c) do item 2802, não houve declaração afirmativa quanto à prática avaliada: na elaboração do PCA são considerados os demais instrumentos de planejamento da organização (E8);
- No subitem d) do item 2802, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o PCA fundamenta a proposta orçamentária da organização (E9);

- No subitem b) do item 2804, não houve declaração afirmativa quanto à prática avaliada: as contratações de TI executadas no exercício encontram-se previamente estabelecidas nos instrumentos de planejamento vigentes (PDTI/PEDTIC e PCA) (E10).

A falta de integração demonstrada entre o planejamento de tecnologia, as previsões orçamentárias, o plano de contratações e as contratações executadas eleva o risco de aquisições isoladas, reativas ou insuficientemente priorizadas sob a perspectiva técnica.

Acompanhamento, revisão e atualização do plano de TIC

O plano de TIC deve ser acompanhado, revisto e atualizado periodicamente ou diante de mudanças relevantes, com registro de execução, pendências, reprogramações e deliberações. Essa rotina permite verificar o andamento das iniciativas, ajustar prioridades e manter o plano compatível com mudanças institucionais, orçamentárias ou tecnológicas.

O Acórdão TCE-RJ 44.490/2024-PLEN prevê a manutenção e revisão periódica do PDTI, bem como ações de divulgação e monitoramento após sua aprovação pela autoridade máxima.

Da análise das respostas ao item 2102 e da documentação apresentada, verificou-se que a rotina de acompanhamento, revisão ou atualização periódica do plano de TIC não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem e) do item 2102, não houve declaração afirmativa quanto à prática avaliada: é feito acompanhamento concomitante à execução do plano de TI, com vistas a assegurar sua observância e possibilitar a realização de ajustes que se fizerem necessário (E11).

A ausência de rotina sistemática de monitoramento e atualização dificulta a adaptação do planejamento de TIC a mudanças no contexto institucional, orçamentário ou tecnológico, elevando o risco de manutenção de iniciativas, prioridades ou metas desatualizadas.

Conclusão

As fragilidades identificadas no planejamento de TIC reduzem a segurança de que a organização disponha, conforme aplicável ao caso concreto, de processo e instrumento suficientes para direcionar iniciativas, priorizar recursos, alinhar projetos às necessidades institucionais e integrar orçamento e contratações à estratégia de tecnologia.

Em razão das lacunas descritas, são propostas recomendações preliminares voltadas à adequação dos aspectos de planejamento de TIC efetivamente apontados neste achado, observados os critérios aplicáveis indicados nas seções anteriores.

Propostas de Encaminhamento

- **Comunicação com Recomendação** para que institua processo formal de planejamento de TIC, compatível com o porte e a maturidade da organização, atentando-se, minimamente, em definir etapas, responsáveis, participação das áreas demandantes e critérios de priorização das necessidades e iniciativas de TIC;
- **Comunicação com Recomendação** para que submeta o plano de TIC à aprovação formal do dirigente máximo ou de dirigente ou colegiado integrante da alta administração, mantendo registro do respectivo ato de aprovação;
- **Comunicação com Recomendação** para que revise o plano de TIC para explicitar seu alinhamento ao planejamento institucional, às diretrizes superiores e às necessidades das áreas finalísticas e administrativas, relacionando objetivos, iniciativas, indicadores e metas de TIC aos resultados institucionais pretendidos;
- **Comunicação com Recomendação** para que integre o plano de TIC à proposta orçamentária, ao plano de contratações e às contratações de TIC, atentando-se, minimamente, em priorizar as demandas conforme sua relevância, seus riscos e a capacidade de execução da organização;
- **Comunicação com Recomendação** para que estabeleça e execute rotina periódica de acompanhamento, revisão e atualização do plano de TIC, atentando-se, minimamente, em registrar a execução das iniciativas, as pendências, as reprogramações e as deliberações adotadas.

Achado 4 – Capacidade institucional insuficiente para sustentar a gestão de TIC e segurança da informação

Critérios

- COBIT 2019, APO01.05 - Estabelecer papéis e responsabilidades: definir, comunicar e manter papéis e responsabilidades relacionados à governança e gestão de TIC;
- COBIT 2019, APO07.01 - Adquirir e manter pessoal adequado e apropriado: assegurar quantidade e perfil de profissionais compatíveis com as necessidades de TIC;
- COBIT 2019, APO07.03 - Manter habilidades e competências do pessoal: identificar, desenvolver e manter competências necessárias à execução das responsabilidades de TIC;
- COBIT 2019, APO07.05 - Planejar e monitorar o uso de recursos humanos de TI e de negócio: planejar, alocar e acompanhar capacidade de pessoal para iniciativas, operações e serviços de TIC;
- ABNT NBR ISO/IEC 27001:2022, cláusulas 5.3 e 7.2: definir responsabilidades e autoridades para segurança da informação e assegurar competências necessárias às funções atribuídas;
- ABNT NBR ISO/IEC 27002:2022, controles 5.2 e 6.3: definir papéis e responsabilidades de segurança da informação e promover conscientização, educação e treinamento em segurança.

Evidências

- **E1:** Ausência de profissionais que atuam regularmente em segurança da informação, conforme informado em resposta ao item 0105;
- **E2:** Resposta negativa ao detalhamento c) do item 2703 do Questionário, para verificar se definiu-se, de maneira documentada, um quantitativo necessário de pessoal da área de tecnologia da informação e segurança da informação;
- **E3:** Resposta negativa ao detalhamento a) do item 2702 do Questionário, para verificar se as responsabilidades e atribuições das ocupações ou grupo de ocupações da área de tecnologia da informação estão definidas, documentadas e publicadas;
- **E4:** Resposta negativa ao detalhamento b) do item 2704 do Questionário, para verificar se os gestores são selecionados com base em perfil profissional previamente definido e documentado, e compatível com o cargo ou função para o qual tenha sido indicado;

- **E5:** Resposta negativa ao detalhamento b) do item 2705 do Questionário, para verificar se as lacunas de competências de liderança e gestão necessárias para a atuação dos gestores da organização são identificadas e documentadas;
- **E6:** Resposta negativa ao detalhamento c) do item 2705 do Questionário, para verificar se as lacunas de competências técnicas da área de tecnologia da informação necessárias para a atuação dos colaboradores da organização são identificadas e documentadas;
- **E7:** Resposta negativa ao detalhamento d) do item 2705 do Questionário, para verificar se as lacunas de competências técnicas da área de segurança da informação necessárias para a atuação dos colaboradores da organização são identificadas e documentadas;
- **E8:** Resposta negativa ao detalhamento a) do item 2706 do Questionário, para verificar se a organização elabora plano de capacitação (plano de treinamento) visando o tratamento das lacunas de competência identificadas.

Situação encontrada

A capacidade institucional de TIC e segurança da informação pressupõe dispor de recursos humanos, competências, perfis profissionais, funções e vínculos contratuais adequados para planejar, coordenar, gerir, proteger, contratar, fiscalizar e sustentar o ambiente tecnológico. Sob a perspectiva de controle e governança, a estruturação formal de uma unidade de tecnologia deve ser acompanhada de capacidade técnica compatível para exercer a supervisão de suas atribuições estratégicas.

Os critérios de boas práticas indicam que a organização deve formalizar a designação de papéis e responsabilidades, assegurar o dimensionamento apropriado do quadro de pessoal, mapear funções críticas, capacitar periodicamente a equipe e supervisionar de forma estrita a atuação de prestadores de serviços externos⁵.

Com base na análise das respostas aos itens 0101, 0105, 2701, 2702, 2703, 2704, 2705, 2706, 2708, 2801 e 2804 do questionário aplicado e da avaliação das evidências documentais anexadas, não foi demonstrada capacidade institucional suficiente para sustentar a gestão de TIC e segurança da informação. A Equipe de Auditoria identificou fragilidades nos seguintes aspectos:

- **Força de trabalho dedicada:** a ausência de força de trabalho dedicada não demonstra aderência aos critérios de pessoal adequado, planejamento de recursos humanos e competências de segurança da informação (COBIT 2019, APO07.01/APO07.05 e ABNT NBR ISO/IEC 27001:2022, cláusulas 5.3 e 7.2),

⁵ Os critérios de capacidade institucional de TIC e segurança da informação concentram-se em pessoal adequado, competências, papéis, responsabilidades, retenção de conhecimento e supervisão de terceiros.

podendo comprometer a execução rotineira das atividades de planejamento, governança e sustentação operacional.

- **Dimensionamento de pessoal:** a ausência de definição de parâmetros de pessoal não demonstra aderência aos critérios de planejamento de recursos humanos (COBIT 2019, APO07.01), elevando o risco de subdimensionamento ou má alocação da equipe técnica.
- **Perfis profissionais:** a ausência ou inobservância de perfis profissionais mínimos para a escolha de gestores e técnicos não demonstra aderência às diretrizes de manutenção de competências (COBIT 2019, APO07.01/APO07.03 e ISO/IEC 27002:2022, 5.2/6.3), reduzindo a segurança de que os responsáveis possuam qualificação compatível com as funções exercidas.
- **Lacunas de competência:** a ausência de identificação ou tratamento de lacunas de treinamento não demonstra aderência às recomendações de capacitação técnica (COBIT 2019, APO07.03 e ISO/IEC 27002:2022, 6.3), podendo fragilizar a operação de segurança e o gerenciamento de ativos de TIC.

Essas situações ensejaram o presente achado e serão detalhadas nas subseções seguintes.

Força de trabalho dedicada à TIC ou à segurança da informação

A organização deve dispor de força de trabalho dedicada à TIC e à segurança da informação, compatível com sua estrutura, porte, serviços prestados, sistemas mantidos, contratações e riscos relevantes.

O COBIT 2019, APO07.01 e APO07.05, orienta a manutenção de pessoal adequado e o planejamento e monitoramento da capacidade de recursos humanos. A ABNT NBR ISO/IEC 27001:2022, cláusulas 5.3 e 7.2, exige responsabilidades definidas e competências necessárias às funções atribuídas em segurança da informação.

Da análise das respostas ao item 0105 e da documentação apresentada, verificou-se que a existência de força de trabalho dedicada à TIC ou à segurança da informação compatível com as responsabilidades da organização não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- Não foi identificada força de trabalho dedicada à segurança da informação no quantitativo informado pela organização (E1).

A inexistência ou insuficiência de profissionais dedicados, em quantitativo compatível com a complexidade do ambiente tecnológico, reduz a segurança quanto à capacidade da organização de executar rotinas essenciais de planejamento, gestão, segurança da informação, contratação, fiscalização contratual e sustentação das operações de TIC.

Quantitativo necessário de pessoal de TIC e segurança da informação

A definição do quantitativo necessário de pessoal permite avaliar se a força de trabalho disponível é compatível com as demandas, riscos e responsabilidades da organização.

O COBIT 2019, APO07.01 e APO07.05, exige que a organização assegure quantidade e perfil de profissionais compatíveis com as necessidades de TIC e planeje a alocação de recursos humanos para iniciativas, operações e serviços.

Da análise das respostas ao item 2703 e da documentação apresentada, verificou-se que a definição do quantitativo necessário de pessoal de TIC e segurança da informação com base em critério ou procedimento técnico não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem c) do item 2703, não houve declaração afirmativa quanto à prática avaliada: definiu-se, de maneira documentada, um quantitativo necessário de pessoal da área de tecnologia da informação e segurança da informação (E2).

A ausência de dimensionamento técnico do quadro de pessoal reduz a disponibilidade de bases objetivas para subsidiar decisões sobre contratações, provimentos, planos de capacitação ou eventual compartilhamento de estruturas com outras organizações.

Perfis profissionais de TIC e segurança da informação

A definição de perfis profissionais mínimos para gestores e colaboradores de TIC e segurança da informação é necessária para que as pessoas designadas possuam competências compatíveis com suas responsabilidades.

O COBIT 2019, APO01.05 e APO07.03, orienta a definição de papéis, responsabilidades e competências necessárias. A ABNT NBR ISO/IEC 27001:2022 também exige competências adequadas às funções atribuídas em segurança da informação.

Da análise das respostas aos itens 2701, 2702 e 2704 e da documentação apresentada, verificou-se que a definição ou utilização de perfis profissionais mínimos para gestores e colaboradores de TIC e segurança da informação não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2702, não houve declaração afirmativa quanto à prática avaliada: as responsabilidades e atribuições das ocupações ou grupo de ocupações da área de tecnologia da informação estão definidas, documentadas e publicadas (E3);
- No subitem b) do item 2704, não houve declaração afirmativa quanto à prática avaliada: os gestores são selecionados com base em perfil profissional previamente

definido e documentado, e compatível com o cargo ou função para o qual tenha sido indicado (E4).

A ausência de perfis profissionais mínimos ou de sua utilização como referência para designação de gestores e técnicos eleva o risco de alocação de colaboradores sem qualificação compatível com atividades críticas de tecnologia da informação e segurança da informação.

Identificação e tratamento de lacunas de competências

A organização deve identificar periodicamente lacunas de competências dos gestores e colaboradores de TIC e segurança da informação e definir medidas de tratamento, como capacitação, realocação, provimento, apoio especializado, compartilhamento de estrutura ou contratação com transferência de conhecimento.

O COBIT 2019, APO07.03, orienta a manutenção de habilidades e competências necessárias à execução das responsabilidades de TIC. A ABNT NBR ISO/IEC 27002:2022, controles 5.2 e 6.3, reforça a definição de responsabilidades e a promoção de conscientização, educação e treinamento em segurança.

Da análise das respostas aos itens 2705 e 2706 e da documentação apresentada, verificou-se que a identificação ou o tratamento de lacunas de competências dos gestores e colaboradores de TIC e segurança da informação não se mostrou suficientemente demonstrado, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem b) do item 2705, não houve declaração afirmativa quanto à prática avaliada: as lacunas de competências de liderança e gestão necessárias para a atuação dos gestores da organização são identificadas e documentadas (E5);
- No subitem c) do item 2705, não houve declaração afirmativa quanto à prática avaliada: as lacunas de competências técnicas da área de tecnologia da informação necessárias para a atuação dos colaboradores da organização são identificadas e documentadas (E6);
- No subitem d) do item 2705, não houve declaração afirmativa quanto à prática avaliada: as lacunas de competências técnicas da área de segurança da informação necessárias para a atuação dos colaboradores da organização são identificadas e documentadas (E7);
- No subitem a) do item 2706, não houve declaração afirmativa quanto à prática avaliada: elabora plano de capacitação (plano de treinamento) visando o tratamento das lacunas de competência identificadas (E8).

A ausência de diagnóstico regular sobre competências internas e de medidas para tratamento de lacunas dificulta o acompanhamento da evolução tecnológica e pode reduzir a

capacidade da equipe técnica de administrar sistemas, infraestrutura e controles de segurança da informação de forma compatível com os riscos existentes.

Conclusão

As fragilidades identificadas na capacidade institucional de TIC e segurança da informação reduzem a segurança de que a organização disponha, conforme aplicável ao caso concreto, de pessoal, competências, papéis, perfis profissionais e mecanismos de supervisão suficientes para sustentar a gestão, a proteção, as contratações, a fiscalização e a continuidade dos serviços tecnológicos.

Em razão das lacunas descritas, são propostas recomendações preliminares voltadas à adequação dos aspectos de capacidade institucional de TIC e segurança da informação efetivamente apontados neste achado, observados os critérios aplicáveis indicados nas seções anteriores.

Propostas de Encaminhamento

- **Comunicação com Recomendação** para que avalie a força de trabalho dedicada à TIC e à segurança da informação e adote medidas proporcionais para assegurar capacidade mínima de planejamento, gestão, proteção, contratação, fiscalização e sustentação dos serviços e ativos de TIC;
- **Comunicação com Recomendação** para que estime e mantenha atualizado o quantitativo necessário de pessoal de TIC e segurança da informação, considerando o porte e a complexidade da organização, os serviços críticos, os sistemas mantidos, as contratações vigentes e os riscos relevantes;
- **Comunicação com Recomendação** para que defina perfis profissionais mínimos para gestores e colaboradores de TIC e segurança da informação, atentando-se, minimamente, em estabelecer conhecimentos, habilidades, experiência e responsabilidades requeridos e utilizar esses perfis na seleção e designação dos responsáveis;
- **Comunicação com Recomendação** para que realize diagnóstico periódico das lacunas de competências dos gestores e colaboradores de TIC e segurança da informação e estabeleça plano de tratamento, contemplando, conforme a necessidade, capacitação, realocação, provimento, apoio especializado, compartilhamento de estrutura ou contratação com transferência de conhecimento.

Achado 5 – Gestão de serviços de TIC insuficiente para assegurar controle sobre serviços, ativos e incidentes

Critérios

- ITIL 4, prática de gerenciamento do catálogo de serviços: manter fonte única de informações consistentes sobre serviços e ofertas de serviço, disponível para usuários e equipes de suporte;
- COBIT 2019, APO09.02 - Catalogar serviços facilitados por TI: definir, manter e comunicar catálogo de serviços, incluindo serviços prestados, características, requisitos e níveis de serviço esperados;
- ITIL 4, prática de gerenciamento de nível de serviço: definir, acordar, monitorar, avaliar e reportar metas e níveis de serviço alinhados às necessidades das áreas usuárias;
- ITIL 4, prática de gerenciamento de ativos de TI: planejar e gerenciar o ciclo de vida dos ativos de TI, mantendo informações suficientes para apoiar controle, custo, risco, valor e tomada de decisão;
- ITIL 4, prática de gerenciamento de configuração de serviço: assegurar informações precisas e confiáveis sobre itens de configuração e seus relacionamentos com serviços, sistemas e infraestrutura;
- COBIT 2019, BAI10.01 - Estabelecer e manter um modelo de configuração: definir escopo, granularidade, atributos, relacionamentos e responsáveis pela base de configuração;
- ITIL 4, prática de gerenciamento de incidentes: minimizar o impacto negativo dos incidentes por meio da restauração tempestiva da operação normal dos serviços e do registro rastreável do tratamento realizado;
- COBIT 2019, DSS02.02, DSS02.04 e DSS02.07 - Requisições de serviço e incidentes gerenciados: registrar, classificar, priorizar, investigar, diagnosticar, resolver, acompanhar e reportar incidentes e requisições de serviço.

Evidências

- **E1:** A organização declarou “Sim” no subitem a) do item 2201, mas a evidência encaminhada foi considerada insuficiente para comprovar que o catálogo contém as metas definidas para cada serviço (p. ex.: prazos de entrega, horários de serviço e de suporte, bem como pontos de contato para solicitação do serviço, envio de sugestões, esclarecimento de dúvidas e reporte de incidentes);

- Justificativa da avaliação: O documento não apresenta um catálogo estruturado com metas de serviço acessível a usuários, contendo apenas disposições contratuais sobre prazos de execução para a futura empresa contratada;
- **E2:** A organização declarou “Sim” no subitem b) do item 2201, mas a evidência encaminhada foi considerada insuficiente para comprovar que o catálogo está atualizado e as informações que nele constam são compatíveis com os Acordos de Níveis de Serviço (ANS) estabelecidos pela área de tecnologia da informação e as áreas de negócio da organização;
 - Justificativa da avaliação: Não foram apresentados Acordos de Nível de Serviço (ANS) firmados entre a TI e as áreas de negócio do DETRAN/RJ, nem evidências de catálogo atualizado que possua compatibilidade verificável com tais acordos;
- **E3:** A organização declarou “Sim” no subitem c) do item 2201, mas a evidência encaminhada foi considerada insuficiente para comprovar que o catálogo é de fácil acesso e está amplamente disponível a seus usuários e às equipes de suporte;
 - Justificativa da avaliação: Não há evidências de publicação ou disponibilização do catálogo para usuários e equipes de suporte, uma vez que o documento base é apenas uma instrução licitatória interna;
- **E4:** A organização declarou “Sim” no subitem d) do item 2201, mas a evidência encaminhada foi considerada insuficiente para comprovar que são formalizados ANS contendo metas de nível de serviço acordadas com representantes das áreas de negócio clientes;
 - Justificativa da avaliação: Os indicadores de desempenho presentes no documento são metas contratuais entre o DETRAN/RJ e a contratada, não configurando ANS formalizados com as áreas de negócio internas da organização;
- **E5:** A organização declarou “Sim” no subitem e) do item 2201, mas a evidência encaminhada foi considerada insuficiente para comprovar que a área de gestão de tecnologia da informação monitora continuamente o alcance dos níveis de serviço estabelecidos nos ANS;
 - Justificativa da avaliação: O documento prevê apenas a obrigatoriedade da futura contratada de emitir relatórios de desempenho, sem que haja demonstração ou evidência de que a TI monitore continuamente tais níveis ou ANS com áreas de negócio;

- **E6:** A organização declarou “Sim” no subitem a) do item 2203, mas a evidência encaminhada foi considerada insuficiente para comprovar que mantém uma base de dados consolidada e atualizada com as configurações dos serviços e ativos de TI e o relacionamento entre eles;
 - Justificativa da avaliação: Não há comprovação da manutenção de uma base de dados consolidada de configurações. Embora o relatório mencione ativos técnicos, não apresenta qualquer evidência de uma CMDB ou registro de relacionamentos entre serviços e ativos, conforme exposto nas páginas 1 e 2 do documento encaminhado. Falta a apresentação do instrumento ou base que consolide essas informações de forma estruturada;
- **E7:** A organização declarou “Sim” no subitem c) do item 2203, mas a evidência encaminhada foi considerada insuficiente para comprovar que o processo de gestão de configuração e ativos está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades);
 - Justificativa da avaliação: O documento encaminhado, um relatório de atividades operacionais, não supre o requisito de formalização do processo. Não foram enviados normativos, políticas ou guias que estabeleçam diretrizes e responsabilidades para a gestão de configuração e ativos. Existe a lacuna quanto à ausência de qualquer documento institucional ou ato normativo que fundamente o referido processo;
- **E8:** A organização declarou “Sim” no subitem a) do item 2204, mas a evidência encaminhada foi considerada insuficiente para comprovar que definiu regras para a priorização e o escalamento de incidentes;
 - Justificativa da avaliação: O documento apresentado registra apenas resultados operacionais, não contendo as regras, matrizes ou diretrizes formais que fundamentem a priorização e o escalonamento. A inexistência de norma ou documento descritivo sobre o fluxo de tratamento impede a verificação deste item. O relatório enviado não supre a necessidade de apresentação da regra institucional de priorização;
- **E9:** A organização declarou “Sim” no subitem d) do item 2204, mas a evidência encaminhada foi considerada insuficiente para comprovar que o(s) processo(s) de gestão de incidentes está(ão) formalizado(s) (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades);

- Justificativa da avaliação: A evidência limita-se a um relatório de desempenho contratual, sem valor normativo ou descritivo da formalização do processo de gestão. O item exige norma interna ou instrumento equivalente de formalização e responsabilidades, que não foi disponibilizado. A ausência de documento normativo instituidor do processo constitui a lacuna principal;
- **E10:** A organização declarou “Sim” no subitem e) do item 2204, mas a evidência encaminhada foi considerada insuficiente para comprovar que definiu procedimentos e responsabilidades quanto à notificação e ao tratamento das notificações de incidentes de segurança da informação, bem como quanto à adoção de ações emergenciais, diretrizes para escalamento e comunicação interna e externa;
 - Justificativa da avaliação: Não há qualquer evidência que aborde incidentes de segurança da informação no documento apresentado. O relatório restringe-se a atividades operacionais de suporte de TI, sem tratar de protocolos de segurança ou ações emergenciais específicas. A ausência total de procedimentos relacionados à segurança da informação torna o item não conforme.

Situação encontrada

A gestão de serviços de TIC organiza a forma como as soluções e o suporte tecnológico são entregues aos usuários e às áreas demandantes do órgão. Catálogo de serviços, Acordos de Nível de Serviço (ANS), inventário de ativos, gestão de configuração e gestão de incidentes constituem práticas básicas e integradas necessárias para assegurar a transparência operacional, continuidade do negócio, governabilidade financeira, controle de ativos e qualidade de suporte técnico.

Os critérios de boas práticas baseados na ITIL 4 e no COBIT 2019 indicam que a organização deve manter fonte unificada e consistente de informações sobre seu catálogo, estabelecer metas mensuráveis de atendimento, administrar ativamente o ciclo de vida dos ativos tecnológicos, rastrear os relacionamentos lógicos de configuração e registrar de forma sistemática e auditável todas as ocorrências operacionais e incidentes de segurança⁶.

Com base na análise das respostas aos itens 2201, 2203, 2204 e 2504 do questionário aplicado e da avaliação das evidências documentais anexadas, não foi demonstrada adoção suficiente dessas práticas mínimas. A Equipe de Auditoria identificou fragilidades nos seguintes aspectos:

⁶ As práticas de gestão de serviços de TIC adotadas como critério baseiam-se em ITIL 4 e COBIT 2019 e abrangem catálogo, níveis de serviço, ativos, configuração e incidentes.

- **Catálogo de serviços de TIC:** a fragilidade ou ausência do catálogo não demonstra aderência à ITIL 4 e ao COBIT 2019 (APO09.02), podendo resultar em prestação reativa, sem transparência ou definição clara das entregas técnicas disponíveis.
- **Níveis mínimos de serviço:** a ausência de parâmetros ou acompanhamento não demonstra aderência aos critérios de catálogo e gerenciamento de nível de serviço (ITIL 4 e COBIT 2019, APO09.02), dificultando a avaliação objetiva da qualidade e tempestividade dos serviços prestados.
- **Inventário de ativos de TIC:** a fragilidade ou inexistência de inventário não demonstra aderência à prática de gerenciamento de ativos de TI (ITIL 4), reduzindo o controle sobre recursos tecnológicos, licenciamentos de software, custos e riscos associados.
- **Gestão de configuração:** a ausência de mapeamento lógico não demonstra aderência à ITIL 4 e ao COBIT 2019 (BAI10.01), podendo prejudicar a confiabilidade das dependências operacionais entre infraestrutura, sistemas e serviços críticos.
- **Gestão de incidentes de TIC:** a inexecução ou informalidade no processo de atendimento não demonstra aderência à ITIL 4 e ao COBIT 2019 (DSS02.02, DSS02.04 e DSS02.07), dificultando o tratamento padronizado, tempestivo e rastreável de falhas tecnológicas.

Essas situações ensejaram o presente achado e serão detalhadas nas subseções seguintes.

Catálogo de serviços de TIC

O catálogo de serviços de TIC deve constituir fonte única de informações consistentes sobre os serviços prestados, acessível aos usuários e às áreas demandantes. Deve conter informações mínimas sobre os serviços efetivamente prestados, suas características, requisitos, canais de atendimento e níveis esperados de serviço.

A ITIL 4, na prática de gerenciamento do catálogo de serviços, orienta a manutenção de informações consistentes e disponíveis sobre serviços e ofertas de serviço. O COBIT 2019, APO09.02, exige a definição, manutenção e comunicação do catálogo de serviços facilitados por TI.

Da análise das respostas ao item 2201 e da documentação apresentada, verificou-se que a existência de catálogo de serviços de TIC atualizado, acessível aos usuários e com informações mínimas sobre os serviços prestados não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2201, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o catálogo contém as metas definidas para cada serviço (p. ex.: prazos de entrega, horários de serviço e de suporte, bem

como pontos de contato para solicitação do serviço, envio de sugestões, esclarecimento de dúvidas e reporte de incidentes) (E1);

- No subitem b) do item 2201, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o catálogo está atualizado e as informações que nele constam são compatíveis com os Acordos de Níveis de Serviço (ANS) estabelecidos pela área de tecnologia da informação e as áreas de negócio da organização (E2);
- No subitem c) do item 2201, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o catálogo é de fácil acesso e está amplamente disponível a seus usuários e às equipes de suporte (E3).

A inexistência, desatualização ou falta de divulgação do catálogo de serviços dificulta que os usuários conheçam o portfólio de entregas e os canais corretos de atendimento, elevando o risco de prestação de suporte de forma reativa, informal ou pouco transparente.

Níveis de serviço e metas de atendimento

A definição de Acordos de Níveis de Serviço, metas mínimas ou parâmetros equivalentes permite pactuar expectativas, medir desempenho e avaliar a qualidade dos principais serviços de TIC.

A ITIL 4, na prática de gerenciamento de nível de serviço, orienta a definição, monitoramento, avaliação e reporte de metas e níveis de serviço alinhados às necessidades das áreas usuárias. O COBIT 2019, APO09.02, também relaciona o catálogo à comunicação de requisitos e níveis de serviço esperados.

Da análise das respostas ao item 2201 e da documentação apresentada, verificou-se que a definição ou o monitoramento de níveis mínimos de serviço, metas ou parâmetros equivalentes para os serviços de TIC relevantes não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem d) do item 2201, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que são formalizados ANS contendo metas de nível de serviço acordadas com representantes das áreas de negócio clientes (E4);
- No subitem e) do item 2201, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que a área de gestão de tecnologia da informação monitora continuamente o alcance dos níveis de serviço estabelecidos nos ANS (E5).

A ausência de níveis mínimos de serviço, metas estruturadas ou parâmetros equivalentes reduz a disponibilidade de bases objetivas para monitorar e avaliar a qualidade, o tempo de resposta e a eficiência dos serviços prestados.

Inventário de ativos de TIC

O inventário de ativos de TIC deve permitir conhecer e controlar equipamentos, servidores, sistemas, *softwares*, licenças, serviços em nuvem, responsáveis e componentes de infraestrutura.

A ITIL 4, na prática de gerenciamento de ativos de TI, orienta o gerenciamento do ciclo de vida dos ativos, mantendo informações suficientes para apoiar controle, custo, risco, valor e tomada de decisão.

Da análise das respostas aos itens 2203 e 2504 e da documentação apresentada, verificou-se que a existência de inventário de ativos de TIC atualizado e abrangente não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2203, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que mantém uma base de dados consolidada e atualizada com as configurações dos serviços e ativos de TI e o relacionamento entre eles (E6).

A ausência de inventário atualizado e abrangente de ativos de TIC reduz a segurança quanto ao controle sobre equipamentos, sistemas, softwares, licenças, serviços em nuvem e componentes de infraestrutura, elevando riscos relacionados a custos, conformidade, segurança da informação e planejamento de capacidade.

Gestão de configuração

A gestão de configuração deve manter informações precisas e confiáveis sobre itens de configuração relevantes, seus atributos, responsáveis e relacionamentos com ativos, sistemas, infraestrutura e serviços.

A ITIL 4, na prática de gerenciamento de configuração de serviço, orienta assegurar informações confiáveis sobre itens de configuração e seus relacionamentos. O COBIT 2019, BAI10.01, exige a definição de escopo, granularidade, atributos, relacionamentos e responsáveis pela base de configuração.

Da análise das respostas ao item 2203 e da documentação apresentada, verificou-se que a existência de processo mínimo de gestão de configuração com registro de itens relevantes, atributos, responsáveis e relacionamentos entre ativos, sistemas, infraestrutura e serviços não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2203, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que mantém uma base de dados consolidada e atualizada com as configurações dos serviços e ativos de TI e o relacionamento entre eles (E6);

- No subitem c) do item 2203, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o processo de gestão de configuração e ativos está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades) (E7).

A ausência de registros suficientes de configuração dificulta o mapeamento lógico das dependências entre servidores, bancos de dados, aplicações e serviços finalísticos, podendo reduzir a capacidade de análise de riscos em mudanças operacionais e de tratamento de falhas sistêmicas.

Gestão de incidentes de TIC

A gestão de incidentes de TIC deve definir papéis, responsabilidades, critérios de priorização, escalamento, tratamento, registro sistemático, histórico das ocorrências e análise posterior de incidentes relevantes ou recorrentes.

A ITIL 4, na prática de gerenciamento de incidentes, orienta minimizar impactos negativos por meio da restauração tempestiva da operação normal e do registro rastreável do tratamento realizado. O COBIT 2019, DSS02.02, DSS02.04 e DSS02.07, exige registrar, classificar, priorizar, investigar, diagnosticar, resolver, acompanhar e reportar incidentes e requisições de serviço.

Da análise das respostas ao item 2204 e da documentação apresentada, verificou-se que a existência de processo mínimo de gestão de incidentes de TIC com papéis, critérios de priorização, escalamento, tratamento, registro sistemático e análise posterior de ocorrências relevantes ou recorrentes não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2204, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que definiu regras para a priorização e o escalamento de incidentes (E8);
- No subitem d) do item 2204, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o(s) processo(s) de gestão de incidentes está(ão) formalizado(s) (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades) (E9);
- No subitem e) do item 2204, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que definiu procedimentos e responsabilidades quanto à notificação e ao tratamento das notificações de incidentes de segurança da informação, bem como quanto à adoção de ações emergenciais, diretrizes para escalamento e comunicação interna e externa (E10).

O tratamento assistemático ou sem registro centralizado das falhas tecnológicas dificulta o acompanhamento do histórico de incidentes, a identificação de causas raiz e a redução do período de indisponibilidade dos sistemas corporativos.

Conclusão

As fragilidades identificadas na gestão de serviços de TIC reduzem a segurança de que a organização disponha, conforme aplicável ao caso concreto, de práticas suficientes para assegurar eficiência, continuidade, rastreabilidade, qualidade dos serviços prestados e controle sobre ativos, configurações e incidentes.

Em razão das lacunas descritas, são propostas recomendações preliminares voltadas à estruturação e à adequação das práticas de gestão de serviços de TIC efetivamente apontadas neste achado, observados os critérios aplicáveis indicados nas seções anteriores.

Propostas de Encaminhamento

- **Comunicação com Recomendação** para que institua e mantenha atualizado catálogo de serviços de TIC, atentando-se, minimamente, em identificar os serviços efetivamente prestados, seus responsáveis, usuários, condições de acesso e informações necessárias ao atendimento das áreas demandantes;
- **Comunicação com Recomendação** para que defina, pactue e monitore níveis mínimos de serviço ou metas de atendimento para os serviços de TIC mais relevantes, estabelecendo indicadores, responsáveis, periodicidade de medição e forma de comunicação dos resultados;
- **Comunicação com Recomendação** para que estabeleça e mantenha atualizado inventário de ativos de TIC, atentando-se, minimamente, em registrar equipamentos, servidores, sistemas, softwares, licenças, serviços em nuvem, componentes de infraestrutura, responsáveis e informações necessárias ao controle do ciclo de vida dos ativos;
- **Comunicação com Recomendação** para que formalize e execute processo de gestão de configuração, atentando-se, minimamente, em manter base, ferramenta ou registro equivalente com os itens de configuração relevantes, seus responsáveis e os relacionamentos entre ativos, sistemas, infraestrutura e serviços, com atualização periódica e uso das informações no planejamento e acompanhamento de mudanças;
- **Comunicação com Recomendação** para que formalize e execute processo de gestão de incidentes de TIC, atentando-se, minimamente, em definir papéis, responsabilidades, critérios de priorização e escalamento, tratamento de incidentes

de serviços e de segurança da informação, registro sistemático e rastreável das ocorrências e análise posterior dos incidentes relevantes ou recorrentes.

SIGILOSO

Achado 6 – Fragilidades na governança técnica da fase preparatória das contratações de TIC

Critérios

- Art. 11, parágrafo único, da Lei 14.133/2021: responsabilidade da alta administração pela governança das contratações, com processos, estruturas, gestão de riscos e controles internos;
- Art. 18, caput e §1º, incisos I, IV, V, VIII, IX, X e XIII, da Lei 14.133/2021: fase preparatória caracterizada pelo planejamento, compatibilização com o plano de contratações anual e elementos mínimos do estudo técnico preliminar;
- Art. 19, inciso IV, da Lei 14.133/2021: instituição de modelos de minutas de editais, termos de referência, contratos padronizados e demais documentos;
- COBIT 2019, BAI02.04 - Obter aprovação dos requisitos da solução: obter aprovação formal dos requisitos funcionais, técnicos, de segurança e de conformidade antes de prosseguir com a solução;
- COBIT 2019, APO01.05 - Estabelecer papéis e responsabilidades: definir e comunicar papéis e responsabilidades relacionados à informação e à tecnologia;
- COBIT 2019, APO01.09 - Definir e comunicar políticas e procedimentos: manter políticas, procedimentos e orientações para direcionar processos de gestão de TIC;
- Instrução Normativa SGD/ME nº 94, de 23 de dezembro de 2022, art. 1º, § 1º: como referência de boa prática, a aplicação de ritos formais de contratação de TIC pode ser facultada para contratações diretas por dispensa em razão do valor (inciso II do art. 75 da Lei nº 14.133/2021), indicando a possibilidade de fluxos simplificados para aquisições de baixa complexidade ou valor.

Evidências

- **E1:** A organização declarou “Sim” no subitem e) do item 2801, mas a evidência encaminhada foi considerada insuficiente para comprovar que o processo de trabalho para a gestão e fiscalização de contratos contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa;
 - Justificativa da avaliação: A Portaria define papéis de gestores e fiscais, contudo, o processo de trabalho para gestão rotineira não está detalhado, limitando-se a procedimentos de aditivos. Falta especificação para acompanhamento contínuo da execução contratual;
- **E2:** Resposta negativa ao subitem a) do item 2804 do Questionário, para verificar se as contratações de soluções de TI, independentemente de qual seja a área

demandante, são obrigatoriamente submetidas à análise prévia e aprovação técnica da área de gestão de TI;

- **E3:** Resposta negativa ao detalhamento c) do item 2102 do Questionário, para verificar se o plano de TI fundamenta a proposta orçamentária da área de TI e o plano de contratações;
- **E4:** Resposta negativa ao detalhamento c) do item 2802 do Questionário, para verificar se na elaboração do PCA são considerados os demais instrumentos de planejamento da organização;
- **E5:** A organização declarou “Sim” no subitem d) do item 2802, mas a evidência encaminhada foi considerada insuficiente para comprovar que o PCA fundamenta a proposta orçamentária da organização;
 - Justificativa da avaliação: A Portaria estabelece o fluxo de verificação de disponibilidade orçamentária por meio da Assessoria de Planejamento e Orçamento (ASSPLAN) em processos de contratação individuais. Não existe evidência documental ou normativa que demonstre que o Plano de Contratações Anual (PCA) sirva como base de fundamentação para a elaboração da proposta orçamentária global da organização;
- **E6:** Resposta negativa ao subitem b) do item 2804 do Questionário, para verificar se as contratações de TI executadas no exercício encontram-se previamente estabelecidas nos instrumentos de planejamento vigentes (PDTI/PEDTIC e PCA).

Situação encontrada

As contratações de TIC devem observar governança técnica, planejamento prévio proporcional à complexidade do objeto, participação da área de tecnologia quando cabível e critérios objetivos para recebimento e mensuração de resultados. A complexidade dos ativos de tecnologia, as exigências de conformidade legal, incluindo LGPD quando aplicável, e a dependência das atividades finalísticas em relação aos serviços de TIC demandam controles compatíveis com a relevância, o risco e o valor da contratação.

Os critérios previstos na Lei 14.133/2021, na Lei 13.709/2018 (LGPD) e nos objetivos do COBIT 2019 disciplinam que a alta administração responde pela governança das contratações, que a fase preparatória deve ser instruída com planejamento compatível com o objeto e que os Termos de Referência (TR), projetos básicos, contratos ou instrumentos equivalentes devem conter requisitos, modelos de execução, critérios de medição e parâmetros de acompanhamento proporcionais à natureza da contratação⁷.

⁷ Os critérios de contratações de TIC combinam requisitos legais da Lei 14.133/2021, requisitos de segurança e proteção de dados da LGPD e boas práticas do COBIT 2019 sobre requisitos, papéis, procedimentos, contratos e desempenho de fornecedores.

Com base na análise das respostas aos itens 2801, 2804, 2102 e 2802 do questionário aplicado e da avaliação das evidências documentais anexadas, não foi demonstrado atendimento suficiente das contratações de TIC da organização a essas diretrizes. A Equipe de Auditoria identificou fragilidades nos seguintes aspectos:

- **Processo de contratação de TIC:** a fragilidade ou ausência de fluxo padronizado contraria a governança de contratações (Lei 14.133/2021, art. 11/art. 19, IV) e o COBIT 2019 (APO01.09), acarretando indefinição de papéis, ritos processuais e prazos internos.
- **Aprovação técnica de TIC:** a falta de avaliação prévia pela área técnica, quando necessária, contraria a governança institucional (COBIT 2019, BAI02.04 e APO01.05), favorecendo aquisições de soluções desalinhadas do ambiente tecnológico existente.
- **Alinhamento ao planejamento:** a ausência de alinhamento demonstrado ao planejamento de TIC, ao plano de contratações ou à proposta orçamentária não demonstra aderência à Lei 14.133/2021 (arts. 11 e 18), podendo resultar em aquisições reativas ou sem lastro orçamentário adequado.

Essas situações ensejaram o presente achado e serão detalhadas nas subseções seguintes.

Processo formal e padronizado para contratações de TIC

O processo de contratação de TIC deve estabelecer fluxo, etapas, papéis, responsabilidades, modelos mínimos de artefatos, manuais, checklists ou orientações internas. Esses elementos reduzem improvisação, aumentam padronização e permitem controle sobre a qualidade da instrução processual.

O art. 11, parágrafo único, da Lei 14.133/2021 atribui à alta administração responsabilidade pela governança das contratações, com processos, estruturas, gestão de riscos e controles internos. O art. 19, inciso IV, prevê a instituição de modelos de documentos padronizados, e o COBIT 2019, APO01.09, orienta a definição e comunicação de políticas e procedimentos.

Da análise das respostas ao item 2801 e da documentação apresentada, verificou-se que a existência de processo formal e padronizado para contratações de TIC, com fluxo, etapas, papéis, responsabilidades, instâncias de aprovação e modelos de artefatos proporcionais ao porte e aos riscos das contratações, não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem e) do item 2801, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o processo de trabalho para a gestão e

fiscalização de contratos contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa (E1).

A ausência de fluxo processual regulamentado e de modelos padronizados reduz a segurança quanto à conformidade das contratações de TIC e eleva o risco de atrasos processuais, indefinição de papéis e inconsistências na elaboração dos documentos da fase preparatória.

Análise prévia e aprovação técnica da área de TIC

As contratações de TIC devem ser submetidas à análise prévia e aprovação técnica da área de TIC, inclusive quando demandadas por outras áreas da organização. Essa análise é necessária para verificar compatibilidade técnica, segurança, integração com o ambiente existente, riscos e aderência a padrões institucionais.

O COBIT 2019, BAI02.04, orienta a obtenção de aprovação formal dos requisitos funcionais, técnicos, de segurança e de conformidade antes de prosseguir com a solução. O COBIT 2019, APO01.05, reforça a definição de papéis e responsabilidades relacionados à informação e à tecnologia. De forma complementar, o art. 1º, § 1º, da Instrução Normativa SGD/ME nº 94/2022, adotado como referência de boa prática, aponta a possibilidade de facultar a aplicação de ritos formais para contratações diretas por dispensa em razão do valor (inciso II do art. 75 da Lei nº 14.133/2021), indicando que os controles e pareceres podem ser proporcionais à relevância estratégica, complexidade e valor da aquisição.

Da análise das respostas ao item 2804 e da documentação apresentada, verificou-se que a submissão das contratações de TIC à análise prévia ou aprovação técnica da área de TIC, inclusive quando demandadas por outras áreas, não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2804, não houve declaração afirmativa quanto à prática avaliada: as contratações de soluções de TI, independentemente de qual seja a área demandante, são obrigatoriamente submetidas à análise prévia e aprovação técnica da área de gestão de TI (E2).

A ausência de análise prévia ou aprovação técnica da área de TIC reduz a segurança de que as soluções contratadas sejam compatíveis com o ambiente tecnológico existente, com os requisitos institucionais e com os controles mínimos de segurança da informação, observada a proporcionalidade em relação à complexidade, ao risco e ao valor da contratação.

Alinhamento ao planejamento, plano de contratações e proposta orçamentária

As contratações de TIC devem estar vinculadas ao planejamento de TIC, ao plano de contratações e à proposta orçamentária. Essa vinculação demonstra que a contratação

decorre de prioridade definida, possui respaldo orçamentário e contribui para objetivos institucionais.

O art. 18 da Lei 14.133/2021 prevê a compatibilização da contratação com o plano de contratações anual e o planejamento da Administração. O art. 11 também reforça a responsabilidade da alta administração pela governança das contratações.

Da análise das respostas aos itens 2102, 2802 e 2804 e da documentação apresentada, verificou-se que o alinhamento das contratações de TIC ao planejamento de TIC, ao plano de contratações ou à proposta orçamentária não se mostrou suficientemente demonstrado, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem c) do item 2102, não houve declaração afirmativa quanto à prática avaliada: o plano de TI fundamenta a proposta orçamentária da área de TI e o plano de contratações (E3);
- No subitem c) do item 2802, não houve declaração afirmativa quanto à prática avaliada: na elaboração do PCA são considerados os demais instrumentos de planejamento da organização (E4);
- No subitem d) do item 2802, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o PCA fundamenta a proposta orçamentária da organização (E5);
- No subitem b) do item 2804, não houve declaração afirmativa quanto à prática avaliada: as contratações de TI executadas no exercício encontram-se previamente estabelecidas nos instrumentos de planejamento vigentes (PDTI/PEDTIC e PCA) (E6).

A ausência de alinhamento das contratações de TIC ao planejamento de TIC, ao plano de contratações ou à proposta orçamentária eleva o risco de fragmentação de despesas, contratações reativas ou insuficientemente priorizadas e uso pouco eficiente dos recursos orçamentários.

Conclusão

As fragilidades evidenciadas na fase preparatória das contratações de TIC reduzem a segurança de que a organização disponha de controles suficientes para assegurar, conforme aplicável ao caso concreto, processo formal de contratação, participação técnica da área de TIC, alinhamento ao planejamento e adequada instrução dos processos. Essas fragilidades elevam o risco de contratações insuficientemente fundamentadas, pouco rastreáveis ou desalinhadas às necessidades institucionais, à complexidade e aos riscos das soluções de TIC pretendidas.

Em razão das lacunas descritas, são propostas recomendações preliminares voltadas à estruturação e à adequação dos aspectos da fase preparatória das contratações

de TIC efetivamente apontados neste achado, observados os critérios aplicáveis indicados nas seções anteriores.

Propostas de Encaminhamento

- **Comunicação com Recomendação** para que formalize e padronize o processo de contratação de TIC, compatível com o porte, a complexidade e os riscos das contratações da organização, atentando-se, minimamente, em definir fluxo, etapas, papéis, responsabilidades, instâncias de aprovação e modelos de artefatos, manuais, listas de verificação ou orientações internas aplicáveis;
- **Comunicação com Recomendação** para que estabeleça a submissão das contratações de TIC à análise prévia da área de TIC, inclusive quando demandadas por outras áreas, de modo a verificar a compatibilidade da solução com os padrões tecnológicos, os requisitos institucionais, a segurança da informação e a arquitetura existente, admitindo fluxos simplificados para contratações de baixa complexidade ou baixo valor, desde que preservada análise técnica mínima compatível com o risco da contratação;
- **Comunicação com Recomendação** para que integre as contratações de TIC ao planejamento de TIC, ao plano de contratações e à proposta orçamentária, atentando-se, minimamente, em registrar a necessidade atendida, a prioridade, a disponibilidade de recursos e a justificativa das situações excepcionais.

4. Plano de ação

Para facilitar o atendimento das propostas constantes da Seção 3, a Equipe de Auditoria elaborou modelo preliminar de plano de ação contendo os encaminhamentos propostos à organização. O quadro não antecipa decisão final desta Corte de Contas e poderá ser revisto após a análise dos comentários do gestor.

Cumpra registrar que, em conformidade com o art. 4º, incisos I e II, da Deliberação TCE-RJ nº 346/2024, cabe à unidade jurisdicionada avaliar a conveniência e a oportunidade de implementar as recomendações. Ressalta-se, contudo, que a eventual decisão pela não aderência deve ser motivada: o gestor deve apresentar justificativa formal que demonstre, à luz das circunstâncias do caso concreto, as razões da decisão e, quando cabível, as medidas alternativas adotadas para tratar a situação que ensejou a recomendação.

Tabela 8 - Plano de ação contendo os encaminhamentos preliminarmente propostos

Achado	Medida proposta	Avaliação de		
		Viabilidade	Quem?	Quando?
2	estabeleça modelo básico de governança e gestão de TIC, atentando-se, minimamente, em definir papéis e responsabilidades, objetivos, indicadores, metas e forma de acompanhamento periódico do desempenho da TIC pela alta administração			
2	institua formalmente Comitê de TIC ou instância equivalente, compatível com o porte e a estrutura decisória da organização, atentando-se, minimamente, em definir sua composição, competências, periodicidade de reuniões, forma de registro das deliberações e acompanhamento dos encaminhamentos			
2	assegure o funcionamento efetivo do Comitê de TIC ou instância equivalente, compatível com o porte e a estrutura decisória da organização, atentando-se, minimamente, em realizar reuniões periódicas, registrar deliberações e acompanhar decisões sobre prioridades, projetos, riscos, serviços, orçamento e contratações de TIC			
3	institua processo formal de planejamento de TIC, compatível com o porte e a maturidade da organização, atentando-se, minimamente, em definir etapas, responsáveis, participação das áreas demandantes e critérios de priorização das necessidades e iniciativas de TIC			
3	submeta o plano de TIC à aprovação formal do dirigente máximo ou de dirigente ou colegiado integrante da alta administração, mantendo registro do respectivo ato de aprovação			

Achado	Medida proposta	Avaliação de		
		Viabilidade	Quem?	Quando?
3	revise o plano de TIC para explicitar seu alinhamento ao planejamento institucional, às diretrizes superiores e às necessidades das áreas finalísticas e administrativas, relacionando objetivos, iniciativas, indicadores e metas de TIC aos resultados institucionais pretendidos			
3	integre o plano de TIC à proposta orçamentária, ao plano de contratações e às contratações de TIC, atentando-se, minimamente, em priorizar as demandas conforme sua relevância, seus riscos e a capacidade de execução da organização			
3	estabeleça e execute rotina periódica de acompanhamento, revisão e atualização do plano de TIC, atentando-se, minimamente, em registrar a execução das iniciativas, as pendências, as reprogramações e as deliberações adotadas			
4	avale a força de trabalho dedicada à TIC e à segurança da informação e adote medidas proporcionais para assegurar capacidade mínima de planejamento, gestão, proteção, contratação, fiscalização e sustentação dos serviços e ativos de TIC			
4	estime e mantenha atualizado o quantitativo necessário de pessoal de TIC e segurança da informação, considerando o porte e a complexidade da organização, os serviços críticos, os sistemas mantidos, as contratações vigentes e os riscos relevantes			
4	defina perfis profissionais mínimos para gestores e colaboradores de TIC e segurança da informação, atentando-se, minimamente, em estabelecer conhecimentos, habilidades, experiência e responsabilidades requeridos e utilizar esses perfis na seleção e designação dos responsáveis			
4	realize diagnóstico periódico das lacunas de competências dos gestores e colaboradores de TIC e segurança da informação e estabeleça plano de tratamento, contemplando, conforme a necessidade, capacitação, realocação, provimento, apoio especializado, compartilhamento de estrutura ou contratação com transferência de conhecimento			
5	institua e mantenha atualizado catálogo de serviços de TIC, atentando-se, minimamente, em identificar os serviços efetivamente prestados, seus responsáveis, usuários, condições de acesso e informações necessárias ao atendimento das áreas demandantes			

Achado	Medida proposta	Avaliação de		
		Viabilidade	Quem?	Quando?
5	defina, pactue e monitore níveis mínimos de serviço ou metas de atendimento para os serviços de TIC mais relevantes, estabelecendo indicadores, responsáveis, periodicidade de medição e forma de comunicação dos resultados			
5	estabeleça e mantenha atualizado inventário de ativos de TIC, atentando-se, minimamente, em registrar equipamentos, servidores, sistemas, softwares, licenças, serviços em nuvem, componentes de infraestrutura, responsáveis e informações necessárias ao controle do ciclo de vida dos ativos			
5	formalize e execute processo de gestão de configuração, atentando-se, minimamente, em manter base, ferramenta ou registro equivalente com os itens de configuração relevantes, seus responsáveis e os relacionamentos entre ativos, sistemas, infraestrutura e serviços, com atualização periódica e uso das informações no planejamento e acompanhamento de mudanças			
5	formalize e execute processo de gestão de incidentes de TIC, atentando-se, minimamente, em definir papéis, responsabilidades, critérios de priorização e escalamento, tratamento de incidentes de serviços e de segurança da informação, registro sistemático e rastreável das ocorrências e análise posterior dos incidentes relevantes ou recorrentes			
6	formalize e padronize o processo de contratação de TIC, compatível com o porte, a complexidade e os riscos das contratações da organização, atentando-se, minimamente, em definir fluxo, etapas, papéis, responsabilidades, instâncias de aprovação e modelos de artefatos, manuais, listas de verificação ou orientações internas aplicáveis			
6	estabeleça a submissão das contratações de TIC à análise prévia da área de TIC, inclusive quando demandadas por outras áreas, de modo a verificar a compatibilidade da solução com os padrões tecnológicos, os requisitos institucionais, a segurança da informação e a arquitetura existente, admitindo fluxos simplificados para contratações de baixa complexidade ou baixo valor, desde que preservada análise técnica mínima compatível com o risco da contratação			
6	integre as contratações de TIC ao planejamento de TIC, ao plano de contratações e à proposta orçamentária, atentando-se, minimamente, em registrar a necessidade atendida, a prioridade, a disponibilidade de recursos e a justificativa das situações excepcionais			



(Fonte: elaboração própria)

SIGILOSO

Apêndice A. Comparabilidade com o ciclo anterior (iGovTI 2023 vs. iGovTI 2026)

A estrutura de 2026 preservou a escala de 0 a 1, as categorias de resposta e as quatro faixas de maturidade empregadas em 2023, mas alterou de forma relevante a composição dos agregados e seus pesos. As principais diferenças estão sintetizadas na Tabela 9.

Tabela 9 - Principais diferenças entre as estruturas do iGovTI 2023 e do iGovTI 2026

Aspecto	iGovTI 2023	iGovTI 2026	Implicação analítica
Composição do índice final	Governança de TIC e Gestão de TIC com pesos iguais de 0,50.	Governança de TIC com peso 0,4777 e Gestão de TIC com peso 0,5223.	A gestão passou a ter participação ligeiramente superior no índice final.
Governança de TIC	Agregação hierárquica de ModeloTI, MonitorAvaliaTI e ResultadoTI.	Agregação direta de quatro práticas relativas ao modelo de gestão, monitoramento, auditoria interna e simplificação de serviços públicos.	O componente tornou-se mais direto e incorporou práticas com escopo distinto da estrutura anterior.
Gestão de TIC	Agregação de Planejamento de TIC, Pessoas e Processos de TIC; este último reunia serviços, níveis de serviço, riscos, segurança, software, projetos e contratos.	Agregação direta das seis dimensões de Gestão de TIC descritas neste relatório.	O índice passou a evidenciar separadamente seis capacidades operacionais e de segurança.
Pessoas e contratações	Pessoas e contratações de TIC integravam o cálculo da Gestão de TIC.	Não integram a árvore de cálculo do iGovTI 2026, embora continuem relevantes para o diagnóstico e para a auditoria.	Mudanças nessas matérias não explicam diretamente a variação do índice de 2026.
Serviços, software e projetos	Serviços e níveis de serviço eram agregados distintos; software e projetos integravam Processos de TIC.	Serviços foram consolidados na dimensão Gestão de Serviços de TIC; software e projetos foram reunidos na dimensão Gestão de Soluções de TIC.	A leitura deve considerar a nova delimitação conceitual dos componentes.

(Fonte: elaboração própria)

Em razão dessas alterações, a diferença entre os valores nominais de 2023 e 2026 não deve ser interpretada automaticamente como evolução ou retrocesso institucional. Uma análise temporal válida exige a harmonização das questões e dos agregados comparáveis, além da consideração de mudanças de escopo, pesos, respondentes e qualidade das evidências.

Para viabilizar a análise longitudinal, foram elaboradas estruturas ajustadas comparáveis para 2023 e 2026, com a manutenção apenas das práticas passíveis de correspondência entre os instrumentos e a aplicação de uma estrutura comum de agregação. Após a normalização das siglas e a validação das correspondências institucionais, foram identificadas 69 organizações presentes nos dois ciclos, equivalentes a 60,5% das organizações com respostas completas em 2026. A comparação individual foi apresentada somente para esse conjunto pareado.

Os resultados ajustados comparáveis têm finalidade exclusivamente analítica. Eles não substituem os índices oficiais de cada ciclo, não eliminam integralmente os efeitos de alterações de respondentes ou de contexto institucional e não constituem, isoladamente, evidência de conformidade ou de inconformidade.

SIGILOSO

Apêndice B. Ajustes nas respostas declaradas

A Equipe de Auditoria, em busca da melhor representação do cenário atual de governança e gestão de TIC, ajustou resposta(s) declarada(s) pela organização **DETRAN** ao questionário iGovTI 2026.

Para tanto, foram utilizadas as justificativas e evidências fornecidas pelo jurisdicionado quando do envio das respostas ao questionário. Ressalta-se que a verificação dessa documentação foi realizada nos termos dos procedimentos definidos para a fiscalização, de modo que nem todas as evidências encaminhadas foram, necessariamente, objeto de análise exaustiva pela Equipe de Auditoria.

Seguem as alterações realizadas após a avaliação das respostas e da amostra de evidências, bem como as justificativas apresentadas pela Equipe:

Tabela 10 - Relação de respostas ajustadas pela Equipe após validação

Questão	Resposta original	Resposta ajustada	Justificativa
q0103[B]	Sim	Não	A evidência apresentada descreve papéis de liderança e gestão da segurança da informação, contudo, carece de dispositivos que detalhem as competências técnicas específicas da área de tecnologia para o desenvolvimento, manutenção e integração de sistemas. A ausência de detalhamento dessas atribuições operacionais em TI constitui uma lacuna documental.
q0103[F]	Sim	Não	Embora a política estabeleça diretrizes sobre a proteção de dados pessoais, ela não define as competências da área de tecnologia quanto à gestão analítica de dados, automação ou inteligência artificial. A carência de normatização para tais funções é um limitante identificado na evidência.
q1001	Adota em maior parte ou totalmente.	Não adota.	A evidência apresentada consiste estritamente em uma Política de Segurança da Informação e Comunicação (POSIC), a qual não supre a necessidade de um modelo abrangente de gestão de tecnologia da informação. Não foram apresentados documentos que comprovem o planejamento estratégico de tecnologia, a gestão corporativa de riscos tecnológicos, a definição de indicadores de desempenho ou a existência de estruturas de governança institucional. A documentação fornecida apresenta lacunas críticas ao restringir-se ao escopo de segurança da informação.

Questão	Resposta original	Resposta ajustada	Justificativa
q1001ext[A]	Sim	Não	A Portaria apresentada aborda diretrizes de segurança da informação, não compreendendo o planejamento estratégico ou tático de tecnologia da informação. Não consta na evidência qualquer normativo que estabeleça diretrizes de planejamento para a área de tecnologia.
q1001ext[B]	Sim	Não	A Política apresentada limita-se a diretrizes de segurança da informação e proteção de dados, não abrangendo a gestão de riscos de tecnologia da informação em âmbito corporativo conforme requerido. Não foram localizados elementos que comprovem diretrizes para riscos de TI além dos de segurança.
q1001ext[C]	Sim	Não	O documento define papéis e responsabilidades restritos à segurança da informação e privacidade, como os previstos nos artigos 13 a 16 da POSIC. Não há evidência que descreva a estrutura de responsabilidades da área de tecnologia da informação em sua totalidade.
q1001ext[D]	Sim	Não	Não há evidências ou menções na documentação fornecida sobre a designação formal de responsáveis das áreas de negócio para a gestão de sistemas informatizados. O documento foca exclusivamente em atribuições de segurança.
q1001ext[E]	Sim	Não	A documentação apresentada não faz qualquer menção à existência ou composição de um comitê de tecnologia da informação. Não foi possível verificar a conformidade deste ponto.
q1001ext[F]	Sim	Não	Dada a inexistência de comprovação documental sobre a constituição ou existência de um comitê de tecnologia da informação, não é possível validar o exercício de suas atividades.
q1001ext[G]	Sim	Não	A evidência fornecida restringe-se a diretrizes de segurança, não contemplando a definição de critérios, indicadores ou diretrizes para a avaliação de desempenho dos serviços de TI em geral.
q1001ext[H]	Sim	Não	Não constam no documento apresentado objetivos, indicadores ou metas para a gestão de TI. A POSIC trata apenas de diretrizes de segurança, sendo insuficiente para atender a este quesito.

Questão	Resposta original	Resposta ajustada	Justificativa
q1002	Adota em maior parte ou totalmente.	Não adota.	A evidência apresentada consiste apenas na Política de Segurança da Informação e Comunicação (POSIC), a qual define diretrizes, normas e responsabilidades institucionais voltadas à segurança e proteção de dados. O documento não apresenta mecanismos, rotinas, indicadores de desempenho, painéis de gestão ou relatórios que comprovem o monitoramento estratégico ou operacional do desempenho da gestão de tecnologia da informação pela alta administração. A lacuna reside na ausência de registros documentais que demonstrem a medição e o acompanhamento sistemático de metas, projetos ou níveis de serviço de TI.
q1002ext[A]	Sim	Não	A POSIC estabelece diretrizes para a segurança da informação, mas não define rotinas, periodicidade ou processos voltados ao monitoramento do desempenho da gestão de tecnologia da informação. A documentação fornecida é insuficiente para atender ao requisito de existência de rotinas de medição de performance da área de TI.
q1002ext[B]	Sim	Não	O documento enviado não contém evidências de planos de TI, metas estabelecidas ou registros que demonstrem o acompanhamento de sua execução. A evidência carece de elementos que liguem a política de segurança à gestão de planos e metas de tecnologia.
q1002ext[C]	Sim	Não	Não foram apresentadas evidências da implantação de indicadores de desempenho (KPIs) voltados à gestão de TI. Não constam documentos que demonstrem a existência de processos para a coleta e análise de dados de performance da área.
q1002ext[D]	Sim	Não	A evidência fornecida não contempla relatórios de medição de desempenho direcionados à liderança ou à alta administração. Inexistem registros ou instâncias documentadas de disponibilização de informações sobre performance de TI.
q1004	Adota em maior parte ou totalmente.	Não adota.	A evidência apresentada é insuficiente para sustentar a adoção das metas de simplificação do atendimento. O conjunto documental enviado consiste exclusivamente em relatórios técnicos de monitoramento de performance e disponibilidade de sistemas de TI. Não foram apresentados planos, estratégias, atas ou documentos de governança que estabeleçam metas formais de simplificação para o atendimento ao usuário.
q1004ext[A]	Sim	Não	Os relatórios de monitoramento de sistemas técnicos não contém elementos que comprovem a existência de metas para a digitalização de serviços. A evidência é limitada a métricas de infraestrutura, sem qualquer registro de planejamento para ampliação da oferta digital.

Questão	Resposta original	Resposta ajustada	Justificativa
q1004ext[B]	Sim	Não	A documentação técnica enviada restringe-se ao controle de disponibilidade de sistemas, não constando qualquer meta de simplificação documental ou integração de bases de dados. Não há evidências que sustentem a existência de metas para a eliminação de exigências documentais.
q1004ext[C]	Sim	Não	Não há evidências nos relatórios técnicos de monitoramento sobre metas de redução de atendimento presencial ou planos de automação de etapas dos serviços públicos. O documento enviado limita-se a métricas operacionais de infraestrutura.
q1004ext[D]	Sim	Não	Os relatórios de TI apresentados não comprovam a existência de metas de interoperabilidade ou integração sistêmica com outros órgãos. A evidência técnica não permite aferir qualquer planejamento de atuação integrada.
q1004ext[E]	Sim	Não	A evidência fornecida é composta apenas por dados de performance de sistemas, sendo insuficiente para demonstrar a existência de metas de otimização de múltiplos canais de atendimento. Não há registro de estratégias para atendimento inclusivo ou redundância de canais.
q1004ext[F]	Sim	Não	Os relatórios de monitoramento de sistemas enviados não comprovam a aplicação da gestão de riscos para promover a simplificação de procedimentos administrativos. Não foram apresentadas evidências sobre a revisão de controles desnecessários com base em avaliação de riscos.
q2201	Adota em maior parte ou totalmente.	Não adota.	A evidência apresentada é um Termo de Referência prospectivo para contratação de serviços, que não constitui um catálogo de serviços vigente e operacionalizado, nem demonstra a efetiva monitoração contínua de níveis de serviço pela organização.
q2201ext[A]	Sim	Não	O documento não apresenta um catálogo estruturado com metas de serviço acessível a usuários, contendo apenas disposições contratuais sobre prazos de execução para a futura empresa contratada.
q2201ext[B]	Sim	Não	Não foram apresentados Acordos de Nível de Serviço (ANS) firmados entre a TI e as áreas de negócio do DETRAN/RJ, nem evidências de catálogo atualizado que possua compatibilidade verificável com tais acordos.
q2201ext[C]	Sim	Não	Não há evidências de publicação ou disponibilização do catálogo para usuários e equipes de suporte, uma vez que o documento base é apenas uma instrução licitatória interna.

Questão	Resposta original	Resposta ajustada	Justificativa
q2201ext[D]	Sim	Não	Os indicadores de desempenho presentes no documento são metas contratuais entre o DETRAN/RJ e a contratada, não configurando ANS formalizados com as áreas de negócio internas da organização.
q2201ext[E]	Sim	Não	O documento prevê apenas a obrigatoriedade da futura contratada de emitir relatórios de desempenho, sem que haja demonstração ou evidência de que a TI monitore continuamente tais níveis ou ANS com áreas de negócio.
q2202	Adota em maior parte ou totalmente.	Não adota.	A evidência apresentada consiste apenas na Política de Segurança da Informação e Comunicação (POSIC), que não estabelece ou detalha um processo de gestão de mudanças de tecnologia. Faltam elementos institucionais, tais como fluxos, responsabilidades, procedimentos de testes e comitês de mudança (CAB) necessários para formalizar a execução deste processo. A evidência é insuficiente para sustentar a afirmação de que a organização executa o processo de gestão de mudanças.
q2202ext[A]	Sim	Não	A política enviada não define critérios técnicos ou operacionais para a aprovação de mudanças, nem estabelece tratamento diferenciado para situações emergenciais. Não há documento complementar que contemple esses requisitos específicos de gestão de mudanças.
q2202ext[B]	Sim	Não	Não consta na documentação apresentada qualquer procedimento que exija ou oriente a comunicação prévia de mudanças de TI às partes interessadas. A evidência limita-se a diretrizes gerais de segurança e não aborda processos de comunicação de mudanças.
q2202ext[C]	Sim	Não	O documento apresentado estabelece princípios gerais de gestão de ativos, contudo, é omissa quanto à identificação de dependências e análise de impacto decorrentes de mudanças em serviços ou níveis de serviço de TI.
q2202ext[D]	Sim	Não	A política de segurança não estabelece a obrigatoriedade de planejamento e testes prévios à execução de alterações no ambiente tecnológico. Não foram fornecidos documentos ou normas operacionais que detalhem essas fases essenciais da gestão de mudanças.
q2202ext[E]	Sim	Não	A documentação fornecida não descreve mecanismos de rastreabilidade ou monitoramento pós-implementação de mudanças. Não há elementos que comprovem a capacidade de avaliação de efetividade ou adoção de ações corretivas em mudanças executadas.

Questão	Resposta original	Resposta ajustada	Justificativa
q2202ext[F]	Sim	Não	A Portaria apresentada institui uma política de segurança da informação, que se caracteriza por diretrizes de alto nível e não como norma técnica de gestão de mudanças de TI. Falta um documento específico que formalize o fluxo, as atribuições e as diretrizes detalhadas para a gestão de mudanças.
q2203	Adota em maior parte ou totalmente.	Não adota.	A evidência apresentada é insuficiente para comprovar a execução do processo de gestão de configuração e ativos de TI. O relatório de atividades de janeiro de 2026, presente nas páginas 1 e 2 do documento '00089_11_2203-relatorio-atividades-periodo-de-01.01.2026-a-31.01.2026.pdf', descreve apenas tarefas operacionais rotineiras, como monitoramento de bancos de dados e backups. Não foi apresentado documento normativo ou registro que demonstre a estruturação desse processo. A lacuna consiste na ausência de evidência que comprove o estabelecimento e a execução sistemática de gestão de configuração e ativos.
q2203ext[A]	Sim	Não	Não há comprovação da manutenção de uma base de dados consolidada de configurações. Embora o relatório mencione ativos técnicos, não apresenta qualquer evidência de uma CMDB ou registro de relacionamentos entre serviços e ativos, conforme exposto nas páginas 1 e 2 do documento encaminhado. Falta a apresentação do instrumento ou base que consolide essas informações de forma estruturada.
q2203ext[B]	Sim	Não	A evidência enviada é insuficiente para demonstrar a vinculação entre uma base de dados de configuração e o processo de mudanças. Embora o relatório liste alterações em sistemas e webservices, na página 1, não há menção ou comprovação de que uma base de configuração foi utilizada como insumo para essas ações. Identifica-se a lacuna de um processo documentado que relacione a base de ativos ao gerenciamento de mudanças.
q2203ext[C]	Sim	Não	O documento encaminhado, um relatório de atividades operacionais, não supre o requisito de formalização do processo. Não foram enviados normativos, políticas ou guias que estabeleçam diretrizes e responsabilidades para a gestão de configuração e ativos. Existe a lacuna quanto à ausência de qualquer documento institucional ou ato normativo que fundamente o referido processo.

Questão	Resposta original	Resposta ajustada	Justificativa
q2204	Adota em maior parte ou totalmente.	Não adota.	A evidência apresentada consiste em relatório operacional de chamados de TI, o qual é insuficiente para comprovar a gestão de incidentes de segurança da informação. Embora existam dados sobre o atendimento de serviços de TI, não foram apresentados documentos que demonstrem a abrangência do processo conforme exigido pelo critério. A ausência de evidências de gestão de incidentes de segurança da informação constitui lacuna crítica.
q2204ext[A]	Sim	Não	O documento apresentado registra apenas resultados operacionais, não contendo as regras, matrizes ou diretrizes formais que fundamentem a priorização e o escalonamento. A inexistência de norma ou documento descritivo sobre o fluxo de tratamento impede a verificação deste item. O relatório enviado não supre a necessidade de apresentação da regra institucional de priorização.
q2204ext[C]	Sim	Não	O relatório apresentado é um documento de apuração de indicadores e não contém informações ou links para repositórios de erros conhecidos. Não há indicação da existência de uma base de conhecimento para suporte à gestão de incidentes. A falta de evidência sobre este repositório torna o item não conforme.
q2204ext[D]	Sim	Não	A evidência limita-se a um relatório de desempenho contratual, sem valor normativo ou descritivo da formalização do processo de gestão. O item exige norma interna ou instrumento equivalente de formalização e responsabilidades, que não foi disponibilizado. A ausência de documento normativo instituidor do processo constitui a lacuna principal.
q2204ext[E]	Sim	Não	Não há qualquer evidência que aborde incidentes de segurança da informação no documento apresentado. O relatório restringe-se a atividades operacionais de suporte de TI, sem tratar de protocolos de segurança ou ações emergenciais específicas. A ausência total de procedimentos relacionados à segurança da informação torna o item não conforme.
q2204ext[F]	Sim	Não	O relatório apresenta apenas justificativas contextuais para atrasos operacionais, sem demonstrar metodologia formal de análise de causa raiz. Não há evidência de plano de ações corretivas ou definição de responsabilidades para análise estruturada de incidentes. A ausência de documento que formalize o procedimento de análise de causa raiz inviabiliza a conformidade.

Questão	Resposta original	Resposta ajustada	Justificativa
q2301	Adota em maior parte ou totalmente.	Não adota.	O processo de gestão de riscos de Tecnologia da Informação não foi comprovado. A evidência enviada, o 'Plano de Resposta a Incidentes de Segurança com Dados Pessoais', trata exclusivamente de ações reativas a incidentes já confirmados ou sob suspeita, conforme detalhado nas páginas 23 a 33, não contemplando as etapas de identificação, avaliação ou tratamento preventivo de riscos de TI nos processos de negócio. A evidência é insuficiente por tratar de um escopo distinto do solicitado.
q2301ext[A]	Sim	Não	A evidência apresentada descreve o fluxo de resposta a incidentes de segurança, conforme páginas 23 a 31, e não demonstra o processo de identificação e avaliação proativa de riscos de TI nos processos organizacionais. Não há evidências de registros ou instrumentos que identifiquem os riscos associados ao uso de TI.
q2301ext[B]	Sim	Não	A documentação fornecida refere-se a um plano de resposta a incidentes, conforme páginas 23 a 31, que possui finalidade diversa de um plano de tratamento de riscos. Não há evidência da existência de um plano de tratamento para riscos de TI.
q2301ext[C]	Sim	Não	O documento apresentado formaliza um processo de resposta a incidentes, não um processo de gestão de riscos de TI. O conteúdo não estabelece normas ou orientações para a execução da gestão de riscos de TI, sendo o escopo da documentação restrito à proteção de dados e resposta a eventos adversos.
q2302	Adota em maior parte ou totalmente.	Não adota.	A organização instituiu normativo que define diretrizes e responsabilidades para a gestão de riscos, conforme evidenciado pela POSIC (Portaria 6739/2025). Contudo, a evidência é insuficiente por não apresentar registros, inventários de risco ou relatórios que demonstrem a execução prática dessas atividades. Persiste a lacuna quanto à comprovação da aplicação efetiva do processo de gestão de riscos de segurança da informação.
q2302ext[A]	Sim	Não	Embora a POSIC estabeleça a diretriz de mapeamento de ameaças e vulnerabilidades, não foram apresentadas evidências documentais de que a identificação e avaliação de riscos estejam sendo efetivamente realizadas. A evidência carece de registros que demonstrem a prática da atividade descrita no normativo.
q2302ext[B]	Sim	Não	Não foram fornecidos documentos que comprovem a existência ou a execução de planos de tratamento de riscos para os ativos de informação da organização. A ausência de planos documentados ou registros de mitigação impede a verificação desta prática.

Questão	Resposta original	Resposta ajustada	Justificativa
q2303	Adota em maior parte ou totalmente.	Não adota.	A evidência fornecida não demonstra a existência de um processo estruturado de gestão de continuidade. O relatório de atividades de TI lista apenas tarefas operacionais rotineiras de manutenção, backup e monitoramento. A ausência de um documento formal de gestão de continuidade torna a evidência insuficiente para sustentar a afirmação.
q2303ext[A]	Sim	Não	Não foi apresentado o Plano de Continuidade de Serviços de TI. A documentação fornecida restringe-se a um relatório de atividades operacionais mensais, que não supre a necessidade de evidenciar o plano de continuidade.
q2303ext[B]	Sim	Não	Não há evidências de realização de análises de impacto no negócio (AIN/BIA). A inexistência de um plano formal impede a verificação da base de fundamentação exigida pela norma.
q2303ext[C]	Sim	Não	Não foram apresentados registros de testes ou revisões periódicas do plano de continuidade. As atividades técnicas citadas são de caráter rotineiro e não se confundem com o ciclo de testes e revisões de um plano de gestão de continuidade.
q2303ext[D]	Sim	Não	Não foi apresentada norma interna, política ou guia que formalize o processo de gestão de continuidade. O relatório de atividades não contém orientações processuais nem definição de responsabilidades conforme exigido.
q2403ext[B]	Sim	Não	A documentação fornecida é insuficiente para demonstrar o nível hierárquico do cargo ou a existência de linha de reporte direto à alta administração. Não foram apresentados organogramas ou atos regimentais que fundamentem a afirmação.
q2403ext[C]	Sim	Não	Embora o documento mencione a designação do gestor, não há descrição detalhada ou comprovação de que ele coordena o processo de gestão de riscos de segurança da informação na instituição.
q2403ext[E]	Sim	Não	Não constam na evidência apresentada informações que comprovem a atuação do gestor na coordenação ou fomento de programas de conscientização e treinamento em segurança da informação.
q2403ext[F]	Sim	Não	Não foram fornecidos documentos ou registros que comprovem a alocação de recursos ou a concessão de prerrogativas específicas ao gestor para o exercício de suas atribuições.

Questão	Resposta original	Resposta ajustada	Justificativa
q2501ext[E]	Sim	Não	A evidência apresentada, a POSIC, trata genericamente da realização de backups, mas não contém dispositivos que operacionalizem o processo de gestão de ativos como suporte a ações mitigatórias específicas para eventos catastróficos que inviabilizem o uso dos ativos. Falta um Plano de Continuidade de Negócios (PCN) ou Plano de Recuperação de Desastres (PRD) que conecte a gestão de ativos a tais cenários críticos.
q2502ext[B]	Sim	Não	Não foram apresentadas evidências documentais que comprovem a aplicação formal dos princípios de necessidade de conhecer e privilégio mínimo. O relatório de atividades enviado restringe-se a descrever tarefas técnicas operacionais sem demonstrar os critérios de concessão de acessos. A ausência de matrizes de permissão ou registros de solicitações justificadas impossibilita a verificação deste requisito.
q2502ext[C]	Sim	Não	O relatório de atividades fornecido não faz menção à utilização de certificados digitais padrão ICP-Brasil em nenhum dos ambientes citados. Não há evidência técnica ou normativa que comprove a adoção desse mecanismo de autenticação para as transações ou acessos descritos. É necessário apresentar documentação técnica que detalhe a configuração ou o uso da ICP-Brasil no controle de acesso.
q2502ext[D]	Sim	Não	Não foram fornecidos registros, atas ou cronogramas que comprovem a realização de auditorias ou revisões periódicas dos direitos de acesso. O documento analisado limita-se a reportar demandas operacionais de inclusão de usuários e tarefas cotidianas. Falta evidência de que os acessos vigentes passam por análise crítica de necessidade e conformidade em intervalos regulares.
q2502ext[E]	Sim	Não	O documento encaminhado constitui um relatório mensal de atividades operacionais, não se confundindo com o instrumento normativo denominado Política de Controle de Acesso. A inexistência de um documento formal que estabeleça princípios, diretrizes e responsabilidades inviabiliza a verificação deste item. É necessária a apresentação da norma institucional de controle de acesso aprovada.
q2503	Adota em maior parte ou totalmente.	Não adota.	O documento apresentado, intitulado 'Plano de Resposta a Incidentes de Segurança com Dados Pessoais', não constitui um processo abrangente de classificação e tratamento de informações conforme exigido. A evidência limita-se a fluxos de resposta a incidentes cibernéticos e não estabelece critérios de classificação (como sigilo ou sensibilidade) ou rotulagem para os ativos de informação da organização em geral.

Questão	Resposta original	Resposta ajustada	Justificativa
q2503ext[A]	Sim	Não	Embora o documento trate de dados pessoais no contexto de incidentes de segurança, não há previsão de um processo formalizado para a identificação e rotulagem contínua desses dados, o que é necessário para assegurar o tratamento e a proteção adequados conforme o item.
q2503ext[B]	Sim	Não	Não foi apresentada evidência comprobatória da disponibilização das informações obrigatórias no sítio eletrônico do órgão. O plano de resposta a incidentes fornecido não supre a falta de transparência ativa exigida pelo item.
q2503ext[C]	Sim	Não	Não foram apresentadas evidências ou normas que estabeleçam a identificação e a rotulagem de informações sigilosas relacionadas à segurança da sociedade ou do Estado. O escopo da evidência enviada é restrito a dados pessoais.
q2503ext[D]	Sim	Não	O documento encaminhado não contempla procedimentos de identificação ou rotulagem para informações amparadas por outras hipóteses legais de sigilo, limitando-se estritamente à governança de dados pessoais em caso de incidentes.
q2503ext[E]	Sim	Não	Embora o glossário mencione 'ativo de informação crítico', não foi demonstrada a existência de um processo formalizado de identificação e rotulagem dessas informações para o negócio. A análise limita-se à categorização técnica de incidentes.
q2503ext[F]	Sim	Não	A evidência apresentada é um 'Plano de Resposta a Incidentes' e não uma norma ou guia de classificação e tratamento de informações. Não há, no instrumento apresentado, orientações abrangentes sobre a execução do processo de classificação e rotulagem dos ativos da organização.
q2504ext[J]	Sim	Não	Apesar de citar 'Políticas de backup robustas' no mapa de riscos como medida de mitigação, o Termo de Referência refere-se apenas a serviços de monitoramento de segurança cibernética e testes de intrusão, não havendo evidência concreta da execução de backups e de testes de recuperação de informações em operação.

Questão	Resposta original	Resposta ajustada	Justificativa
q2505	Adota em maior parte ou totalmente.	Não adota.	A evidência apresentada, composta pela Política de Segurança da Informação e Comunicação (POSIC), estabelece apenas diretrizes normativas e responsabilidades organizacionais sobre o tema. Não foram fornecidos registros, relatórios, certificados ou cronogramas que comprovem a efetiva realização, implementação e periodicidade de tais ações de treinamento ou capacitação. A ausência de elementos comprobatórios da execução prática torna a evidência insuficiente para sustentar a conformidade alegada.
q2505ext[A]	Sim	Não	Embora o normativo institucional preveja a realização de capacitação, não há documentação comprobatória da execução dessas ações. A evidência limita-se à previsão legal, carecendo de registros que confirmem a efetividade das ações de capacitação mencionadas.
q2505ext[B]	Sim	Não	O documento institucional define a obrigatoriedade da participação dos colaboradores em cursos, mas não apresenta evidências da participação efetiva por parte do quadro de pessoal. Não há registros, certificados ou relatórios que comprovem que a organização e seus colaboradores tenham participado de tais ações.
q2505ext[C]	Sim	Não	A normativa estabelece a responsabilidade de implementar medidas de conscientização, porém não foram fornecidos elementos que comprovem a realização concreta dessas atividades. Falta a comprovação documental de campanhas, materiais educativos ou comunicações internas realizadas.
q2505ext[D]	Sim	Não	A evidência apresentada resume-se ao arcabouço normativo que institui a Política de Segurança, não demonstrando a existência ou a operacionalização de um programa permanente de conscientização. A ausência de evidências da execução prática impede a confirmação do item.
q2601	Adota parcialmente.	Não adota.	A documentação apresentada refere-se exclusivamente à Política de Segurança da Informação e Comunicação, não evidenciando a existência de um processo de engenharia de software. Não foram fornecidos manuais, guias ou normas técnicas que descrevam o ciclo de vida, metodologias de desenvolvimento ou a gestão operacional de softwares.
q2601ext[A]	Sim	Não	A evidência apresentada não aborda os fluxos de desenvolvimento ou aquisição de software. Não é possível constatar a participação formal de representantes da área de negócio em ciclos de vida de software.

Questão	Resposta original	Resposta ajustada	Justificativa
q2601ext[B]	Sim	Não	Embora a política mencione a proteção da informação em contratações, não há descrição de um processo de software que integre requisitos de segurança ao longo do ciclo de vida. O documento foca em diretrizes gerais de segurança e não em metodologias de engenharia de software.
q2601ext[C]	Sim	Não	A evidência fornecida não contém orientações, normas ou registros sobre a identificação e o acompanhamento de requisitos de acessibilidade e usabilidade em sistemas.
q2601ext[D]	Sim	Não	Não constam na documentação diretrizes ou cláusulas contratuais específicas sobre a titularidade de direitos autorais e de propriedade intelectual de softwares contratados ou desenvolvidos.
q2601ext[E]	Sim	Não	A evidência enviada é insuficiente, pois trata apenas de diretrizes de segurança. Não há registros de indicadores, metas ou processos de medição de qualidade de software.
q2601ext[F]	Sim	Não	A Portaria apresentada refere-se à governança de segurança da informação e não supre a necessidade de formalização de um processo de engenharia de software.
q2602ext[C]	Sim	Não	A evidência enviada limita-se a demonstrar o acompanhamento operacional e cronogramas, não contemplando registros, matrizes ou planos de gestão de riscos. A suficiência da evidência é insuficiente por não apresentar elementos sobre a atividade de gestão de riscos. Falta a comprovação de instrumentos ou registros de controle específicos para riscos em projetos de alta relevância.
q2701	Adota em maior parte ou totalmente.	Não adota.	A evidência apresentada, a Política de Segurança da Informação e Comunicação (POSIC), define papéis e atribuições operacionais, mas não apresenta o perfil profissional desejado para as ocupações de gestão de TI. Falta a descrição detalhada de competências, habilidades, qualificações e requisitos exigidos para esses cargos. A evidência é insuficiente por não conter elementos que caracterizem o perfil profissional solicitado.
q2701ext[C]	Sim	Não	A documentação apresentada limita-se a elencar atribuições funcionais e responsabilidades relativas à segurança da informação, não relacionando competências técnicas, gerenciais ou habilidades específicas para os ocupantes dos cargos. A evidência é insuficiente por não apresentar o detalhamento do perfil profissional exigido pelo requisito.

Questão	Resposta original	Resposta ajustada	Justificativa
q2701ext[D]	Sim	Não	Embora a POSIC seja um documento público, não foram apresentados perfis profissionais definidos contendo competências e habilidades, nem evidências de que tais perfis tenham sido disponibilizados via mecanismos de transparência ativa. O elemento faltante é a comprovação da existência e da publicidade ativa de perfis profissionais de gestão de TI.
q2705	Adota em maior parte ou totalmente.	Não adota.	A Política de Segurança da Informação (POSIC) apresentada estabelece diretrizes e responsabilidades institucionais, mas não constitui prova da efetiva execução do processo de identificação e documentação de lacunas. Não foram apresentados registros, diagnósticos, matrizes de competências ou planos de capacitação que comprovem a identificação de lacunas para os públicos descritos. Faltam evidências operacionais que demonstrem a aplicação prática das responsabilidades previstas na norma.
q2705ext[A]	Sim	Não	A evidência restringe-se a instituir normas e diretrizes de segurança, sem contemplar registros que identifiquem lacunas de competências pessoais transversais. Não foram fornecidos diagnósticos, levantamentos ou relatórios que comprovem a existência de um processo de identificação destas competências. Faltam elementos documentais específicos que comprovem a análise de gaps transversais.
q2705ext[B]	Sim	Não	A documentação apresentada não contém registros, relatórios ou matrizes de competências gerenciais que comprovem a identificação de lacunas de liderança. A POSIC define responsabilidades, mas não detalha ou evidencia a avaliação das competências necessárias aos gestores. Faltam documentos que evidenciem o diagnóstico de necessidades de desenvolvimento para este público.
q2705ext[C]	Sim	Não	Não foram apresentados elementos que demonstrem a identificação de lacunas técnicas em tecnologia da informação. A norma estabelece papéis institucionais, mas carece de diagnósticos, planos de desenvolvimento ou matrizes técnicas que comprovem a avaliação das competências dos colaboradores da área. Faltam registros documentais de identificação de gaps técnicos.

Questão	Resposta original	Resposta ajustada	Justificativa
q2705ext[D]	Sim	Não	A evidência apresentada não contempla o diagnóstico ou a documentação de lacunas técnicas específicas da área de segurança da informação. Embora a política preveja conscientização, não foram apresentados registros ou matrizes de competências que identifiquem falhas ou necessidades de aprimoramento técnico. Faltam documentos comprobatórios do processo de identificação de lacunas técnicas em segurança.
q2706	Adota parcialmente.	Não adota.	A evidência apresentada (POSIC) estabelece apenas a obrigatoriedade de um curso de conscientização genérico para todos os colaboradores, sem contemplar o tratamento de lacunas de competências técnicas específicas para a área de tecnologia e segurança da informação. A documentação normativa é insuficiente, pois não demonstra o diagnóstico das necessidades de treinamento nem a execução de planos estruturados para o público-alvo da questão. Inexiste evidência sobre a identificação ou o tratamento direcionado de lacunas de competências técnicas.
q2706ext[B]	Sim	Não	A política apresentada aborda apenas o incentivo à conscientização sobre as normas internas de segurança, não configurando incentivo à participação em programas de capacitação técnica profissional. Não foram apresentadas evidências de mecanismos, programas ou campanhas de incentivo ao desenvolvimento de competências específicas para os colaboradores e gestores das áreas de TI e segurança.
q2707	Adota em maior parte ou totalmente.	Não adota.	A evidência apresentada, a Política de Segurança da Informação e Comunicação (POSIC), estabelece diretrizes e responsabilidades, mas não contempla a avaliação de desempenho individual. Não há documento normativo, registro, nota ou conceito de avaliação que comprove o alcance de metas para o pessoal de TI ou de Segurança da Informação. A suficiência da evidência é nula quanto ao objeto auditado. Existe a lacuna completa de instrumentos formais que descrevam o processo de avaliação de desempenho individual.
q2707ext[A]	Sim	Não	O documento encaminhado trata exclusivamente da Política de Segurança da Informação e Comunicação, não possuindo previsão de normas para avaliação de desempenho de colaboradores e gestores da instituição. A evidência é insuficiente para sustentar a afirmação. Falta o normativo específico de gestão de pessoas voltado à avaliação de desempenho.

Questão	Resposta original	Resposta ajustada	Justificativa
q2707ext[D]	Sim	Não	Não há evidência de que a organização realize a avaliação de desempenho para colaboradores da área de tecnologia da informação. A documentação fornecida é limitada à Política de Segurança da Informação e não cobre aspectos de gestão de RH. Existe a lacuna de evidências da aplicação prática dessa avaliação para a referida área.
q2707ext[E]	Sim	Não	Não foi apresentada evidência que demonstre a existência de avaliação de desempenho para os colaboradores da área de segurança da informação. O material enviado restringe-se às diretrizes da política de segurança, não abrange processos de gestão de pessoas. Falta a comprovação de critérios e registros de avaliação aplicados a estes profissionais.
q2801ext[E]	Sim	Não	A Portaria define papéis de gestores e fiscais, contudo, o processo de trabalho para gestão rotineira não está detalhado, limitando-se a procedimentos de aditivos. Falta especificação para acompanhamento contínuo da execução contratual.
q2801ext[F]	Sim	Não	Não foram disponibilizados modelos para os artefatos fundamentais de gestão contratual citados na norma, restando a padronização limitada a checklists de prorrogação e quadros demonstrativos mensais.
q2802	Adota em maior parte ou totalmente.	Não adota.	A evidência normativa apresentada, a Portaria DETRAN SEI N.º 6645/2024, disciplina o fluxo de contratações individuais e a fase preparatória de processos específicos, mas não comprova a existência ou a execução de um processo de planejamento anual consolidado de contratações (PCA). Embora o instrumento cite a previsão no PCA como requisito para contratações isoladas, não há nos documentos apresentados evidência da elaboração, aprovação ou monitoramento do Plano de Contratações Anual enquanto instrumento de planejamento global da organização.
q2802ext[B]	Sim	Não	A norma evidencia a participação de setores e Câmaras Temáticas na instrução e no planejamento de contratações individuais e específicas. Contudo, não há elementos que demonstrem a participação colaborativa desses setores na elaboração do Plano de Contratações Anual enquanto instrumento de planejamento macro da entidade.
q2802ext[D]	Sim	Não	A Portaria estabelece o fluxo de verificação de disponibilidade orçamentária por meio da Assessoria de Planejamento e Orçamento (ASSPLAN) em processos de contratação individuais. Não existe evidência documental ou normativa que demonstre que o Plano de Contratações Anual (PCA) sirva como base de fundamentação para a elaboração da proposta orçamentária global da organização.

Questão	Resposta original	Resposta ajustada	Justificativa
q2803	Adota em maior parte ou totalmente.	Não adota.	A organização demonstra a utilização do portal oficial para divulgação, porém a evidência é insuficiente para atestar a publicidade integral das fases de planejamento e seleção. O documento apresentado comprova apenas a existência de um empenho no repositório. Falta a comprovação documental do ciclo completo da contratação, especificamente ETP, TR e etapas de seleção.
q2803ext[A]	Sim	Não	A evidência apresentada restringe-se a uma nota de empenho. Não há registro ou documento que comprove a disponibilização do Estudo Técnico Preliminar no portal indicado. É necessária a apresentação do documento ou do link de acesso ao ETP.
q2803ext[B]	Sim	Não	O documento exibido refere-se exclusivamente a dados orçamentários de empenho. A organização não comprovou a publicidade do Termo de Referência conforme exigido. Falta a demonstração da publicação do TR correspondente.
q2803ext[C]	Sim	Não	A evidência anexada trata de uma nota de empenho e não contempla o aviso ou edital de contratação. O elemento de prova é insuficiente para demonstrar o cumprimento deste item. Falta a apresentação de documento relativo ao aviso ou edital publicado.
q2803ext[D]	Sim	Não	A documentação apresentada não contém atas de registro de preços ou de julgamento. O comprovante limita-se à emissão de empenho, o que não atende à amplitude do requisito. Falta a apresentação de ata publicada no referido portal.
q2803ext[G]	Sim	Não	A evidência fornecida refere-se apenas ao empenho inicial, não havendo qualquer registro sobre prorrogação contratual. Para a conformidade, é necessário que a justificativa e análise de prorrogação estejam publicadas. Falta a documentação relativa a aditivos ou prorrogações.
q2101	Adota em maior parte ou totalmente.	Não adota.	A avaliação realizada indica que o processo de planejamento de TI não está implementado no órgão. Os documentos apresentados referem-se a designações de pessoal para áreas diversas, como LGPD e segurança da informação, e a normas de contratação externas ao planejamento estratégico de tecnologia. A evidência é insuficiente para atestar a existência de planejamento de TI, dada a ausência de planos vigentes (PDTI/PETIC) ou registros institucionais correlatos.

Questão	Resposta original	Resposta ajustada	Justificativa
q2101ext[A]	Sim	Não	A avaliação realizada indica que não há comprovação da participação de áreas demandantes no planejamento de TI. Não foram apresentados registros, atas ou normativos que evidenciassem tal envolvimento nas ações de tecnologia da informação. A evidência é insuficiente, dada a ausência total de documentação que relacione demandas de áreas internas com o planejamento de tecnologia.
q2101ext[B]	Sim	Não	A avaliação realizada indica que a organização não estabeleceu critérios formais de seleção e priorização de iniciativas de TI. O pacote probatório não contém matrizes, rankings, catálogos de priorização ou instrumentos análogos que orientem decisões de TI. A evidência é insuficiente por omitir a formalização de critérios técnicos ou gerenciais para a priorização de investimentos em tecnologia.
q2101ext[C]	Sim	Não	A avaliação realizada indica a inexistência de análises de benefícios, custos ou riscos para subsidiar decisões de TI. Não constam estudos de viabilidade, business cases ou análises multicritério referentes a projetos de tecnologia da informação. A evidência é insuficiente devido à ausência de documentos técnicos que fundamentem a seleção ou priorização de iniciativas de TI.
q2101ext[D]	Sim	Não	A avaliação realizada indica que o processo de planejamento de TI não está formalizado. Não foi apresentado normativo interno, guia ou portaria que discipline a execução do planejamento, a definição de responsabilidades e as orientações para o processo de TI no âmbito da organização. A evidência é insuficiente pela total ausência de instrumento formal que regule a governança e o planejamento de TI.

(Fonte: elaboração própria)